



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services



دبلوم امن المعلومات

الفصل الثالث: نماذج التهديد وتحليل المخاطر



دبلوم امن المعلومات

● اسم المقرر:

مبادئ التصميم في الأمن السبراني

● رمز المقرر:

ISE125

● الموضوع:

الفصل الثالث: نماذج التهديد وتحليل المخاطر



يطبق نموذج STRIDE على مكونات نظام ذي حدود ثقة واضحة.



يميز مفاهيم التهديد والثغرة والأثر والمخاطر في سياق التصميم.

يقارن مسارات التعامل مع الثغرات الأمنية.



يحلل مخاطر تصميم بمصفوفة احتمال وأثر ويقترح معالجة مناسبة.



يقيّم احتمال توثيق نموذج تهديد من منظور أخلاقي.



خريطة الفصل

يتدرج الفصل عبر ستة محاور مترابطة:





- ◀ ينفذ الفصل في ست وحدات مستقلة، مدة كل وحدة 60 دقيقة.
- ◀ تشمل الدراسة 175 دقيقة، والأنشطة 85 دقيقة، والتقييمات 60 دقيقة، والمشروع 40 دقيقة.
- ◀ يدرس المتعلم المفاهيم والوثائق 146 دقيقة، ثم ينفذ مراجعة موجهة مدتها 29 دقيقة تربط الأصول والحدود والتهديدات والقرارات.



خطة الوحدات الزمنية (تابع)



الوحدة	المحاور والمخرج	الزمن
1	التهديد والثغرة والأصل وحدود الثقة، وتحديد ثلاثة انتقالات	60 د
2	نموذج التهديد وتعبئة نطاق خدمة رفع المستندات	60 د
3	STRIDE وتصنيف سيناريوهات الخدمة الستة	60 د
4	الاحتمال والأثر وقراءة جدول المخاطر	60 د
5	المعالجة والضوابط التعويضية والإفصاح المسؤول	60 د
6	مراجعة موجهة، اختبار قصير، واجب، ومرحلة المشروع	60 د

التهديد هو احتمال وجود سبب أو حدث ضار قد يؤثر في أصل معلوماتي أو خدمة.

لا يساوي التهديد الثغرة أو الأثر أو الخطر. في خدمة رفع المستندات، قد يكون استخدام رمز جلسة مسروق تهديداً، لأنه قد يسمح بالوصول غير المصرح به إلى ملفات العملاء إذا توافرت ظروف تمكنه.



الثغرة الأمنية هي ضعف أو حالة مهينة يمكن أن تسهم في تحقق حدث ضار.

لا يكفي وجود الثغرة وحده للحكم على مستوى المخاطر. مثال ذلك رابط تخزين لا يفرض تفويضاً دقيقاً، إذ يصبح خطراً عند ارتباطه بمستندات العملاء، وإمكان الوصول إليها، والأثر المتوقع على السرية والالتزامات التنظيمية.



الأثر الأمني هو العاقبة المتوقعة عند تحقق تهديد على أصل محدد.

يقدر الأثر في سياق الجهة والخدمة، وليس بصورة ثابتة لكل الأنظمة. قراءة مستندات العملاء من مسار تخزين غير محمي قد تؤثر في سرية البيانات الشخصية، بينما قد يكون الأثر أقل في خدمة داخلية لا تحتوي معلومات حساسة.



المخاطر تقدير منظم لاحتمال تحقق أثر ضار وشدته على أصل أو خدمة في سياق محدد.

تربط المخاطر بين أصل وتهديد وثغرة وأثر واحتمال وقرار معالجة. لذلك لا يصح وصف كل ضعف تقني بأنه خطر حرج قبل بيان الأصل المتأثر، والظروف التي تتيح الاستغلال، وعواقب الحدث.



- ◀ الأصل المعلوماتي شيء ذو قيمة ينبغي حمايته، مثل البيانات والخدمات والحسابات والمكونات.
- ◀ يبدأ التحليل بجدد الأصل وتصنيف أهميته وحساسيته واعتمادياته وأثر فقدانه.
- ◀ **الوظيفة:** تحديد ما يستحق الحماية قبل تحليل التهديدات، لأن التهديد لا يكتسب أولوية دون أصل متأثر.
- ◀ **المسؤوليات:** جرد الأصل، أي حصره في سجل واضح، تعيين مالك مسؤول، أي جهة تتابع قراره، تحديد الحساسية، أي أثر الكشف أو التعديل، توثيق الاعتماديات، أي الخدمات المرتبطة به، ربط الأصل بالأثر، أي تبرير درجة الخطر.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-30 Rev. 1، وهو مرجع مقرر لتقييم المخاطر وتقدير الأثر.
- ◀ **الأدوات:** مخطط تدفق البيانات، سجل أصول، جدول تصنيف بيانات.
- ◀ **المخرج:** سجل أصل أو صف في جرد الأصول.
- ◀ **مثال:** تشمل أصول النموذج TM-2026-014 ملفات الهوية والشهادات، ورموز الجلسات، وسجلات التدقيق.



الأصل المعلوماتي وتصنيف الأصول (Information Asset Classification) (تابع)



الأصل في TM-2026-014	متطلب الحماية المرتبط	سبب الربط
ملفات الهوية والشهادات	السرية	تحتوي مستندات العملاء
رموز الجلسات	منع الوصول غير المصرح به	ترتبط بهوية العميل
سجلات التدقيق	إثبات العمليات	توثق الرفع والمراجعة

◀ **مثال محلول:**

◀ **المعطيات:** يسجل النموذج TM-2026-014 ستة أصول هي الملفات، وبيانات الطلبات، ورموز الجلسات، وسجلات التدقيق، وحسابات الموظفين، وإعدادات التخزين السحابي.

◀ **الخطوات:**

1. نعد الأصول المسجلة، فيكون العدد 6.
 2. نربط ملفات الهوية بمتطلب السرية، لأن كشفها يضر بمستندات العملاء.
 3. نربط سجلات التدقيق بإثبات عمليات الرفع والمراجعة، لأن غيابها يضعف إثبات العملية.
- ◀ **النتج:** جرد الأصول يكون 6 صفوف قابلة للتحليل.

◀ ويبدأ تقدير الخطر من الأصل ثم التهديد والثغرة، لا من اسم الثغرة وحده.

نموذج جرد الأصول لخدمة رفع المستندات



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شركة الحلول التقنية والخدمات الرقمية تطوير وإدارة المنصات الرقمية والخدمات السحابية جازان، المملكة العربية السعودية الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000 هاتف: 0500000000		
النموذج: تحديد نطاق التهديد		
نموذج تحديد نطاق التهديد		
معرف النموذج: TM-2026-014		
تاريخ الإعداد: 2026-03-16		
الخدمة محل التحليل: خدمة رفع مستندات العملاء ضمن منصة رقمية سحابية		
غرض الخدمة: استقبال مستندات العملاء والتحقق من نوعها وتخزينها لإتاحة مراجعتها للموظفين المخولين.		
الكيانات الخارجية: العمل عبر المتصفح، وخدمة تحقق خارجية عبر نفاذ.		
مكونات المعالجة الداخلية: بوابة الويب في منطقة معزولة، خدمة فحص الملفات، واجهة إدارة الموظفين، قاعدة بيانات الطلبات، ومخزن مستندات داخلي.		
تدفقات البيانات: يرسل العميل ملفاً وبيانات وصفية إلى بوابة الويب. ترسل البوابة طلب تحقق إلى الخدمة الخارجية. يمر الملف إلى خدمة الفحص ثم إلى مخزن المستندات، وتسجل قاعدة البيانات حالة الطلب وسجل التدقيق.		
حدود الثقة: الحد الأول بين متصفح العميل وبوابة الويب، الحد الثاني بين بوابة الويب وخدمة التحقق الخارجية، الحد الثالث بين منطقة البوابة المعزولة والشبكة الداخلية التي تضم قاعدة البيانات ومخزن المستندات.		
الأصول المعلوماتية: ملفات الهوية والشهادات، بيانات الطلبات، رموز الجلسات، سجلات التدقيق، حسابات الموظفين، وإعدادات التخزين السحابي.		
متطلبات الحماية: حماية سرية المستندات وتكاملها، منع الوصول غير المصرح، إتاحة الخدمة للعملاء، وإثبات عمليات الرفع والمراجعة.		
نطاق الالتزام: تطبيق المنشأة ضوابط مناسبة لحماية البيانات الشخصية وفق نظام حماية البيانات الشخصية، وتراجع الضوابط الأساسية للأمن السيبراني الصادرة عن الهيئة الوطنية للأمن السيبراني.		
يستعمل هذا النموذج مدخلاً لورقة تصنيف STRIDE وسجل المخاطر المرتبطين بالمعرفات R-01 إلى R-06.		
مقدم الطلب	المسؤول	الاعتماد
مستند تعليمي إداري، الأسماء والأرقام غير حقيقية		

- يساعد المستند على قراءة نطاق الخدمة قبل تعداد التهديدات.
- حدد ملفات الهوية والشهادات، وبيانات الطلبات، ورموز الجلسات، وسجلات التدقيق، وحسابات الموظفين، وإعدادات التخزين السحابي بوصفها أصولاً.
- ثم اربط كل أصل بمتطلب حماية، مثل السرية أو تكامل البيانات أو التوافر أو إثبات عملية الرفع والمراجعة.

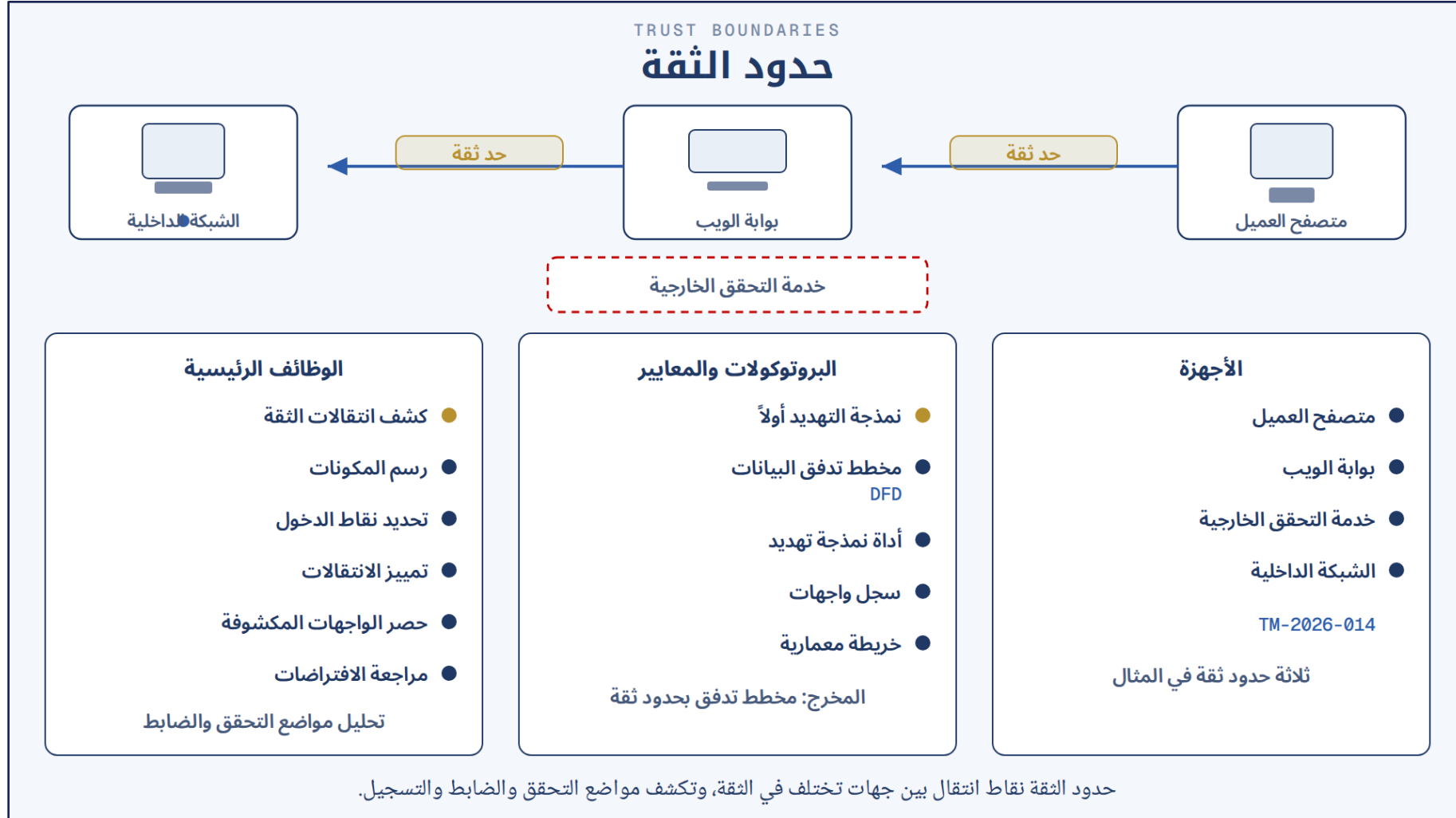


حدود الثقة (Trust Boundaries)

- ◀ حدود الثقة هي نقاط انتقال البيانات أو الطلبات بين مكونات أو جهات تختلف في مستوى الثقة أو الصلاحيات.
- ◀ تكشف هذه الحدود المواضيع التي تحتاج تحققاً أو ضابطاً أو تسجيلاً أمنياً.
- ◀ **الوظيفة:** كشف انتقالات الثقة التي تستحق التحليل.
- ◀ **المسؤوليات:** رسم المكونات، تحديد نقاط الدخول، تمييز الانتقالات، حصر الواجهات المكشوفة، مراجعة الافتراضات.
- ◀ **القواعد:** نمذجة التهديد تسبق اختيار الضوابط التقنية.
- ◀ **الأدوات:** مخطط تدفق البيانات، أداة نمذجة تهديد، سجل واجهات، خريطة معمارية.
- ◀ **المخرج:** مخطط تدفق موضح عليه حدود الثقة.
- ◀ **مثال:** يتضمن TM-2026-014 حداً بين متصفح العميل وبوابة الويب، وآخر مع خدمة التحقق الخارجية، وثالثاً مع الشبكة الداخلية.



(الشكل) (Trust Boundaries) حدود الثقة



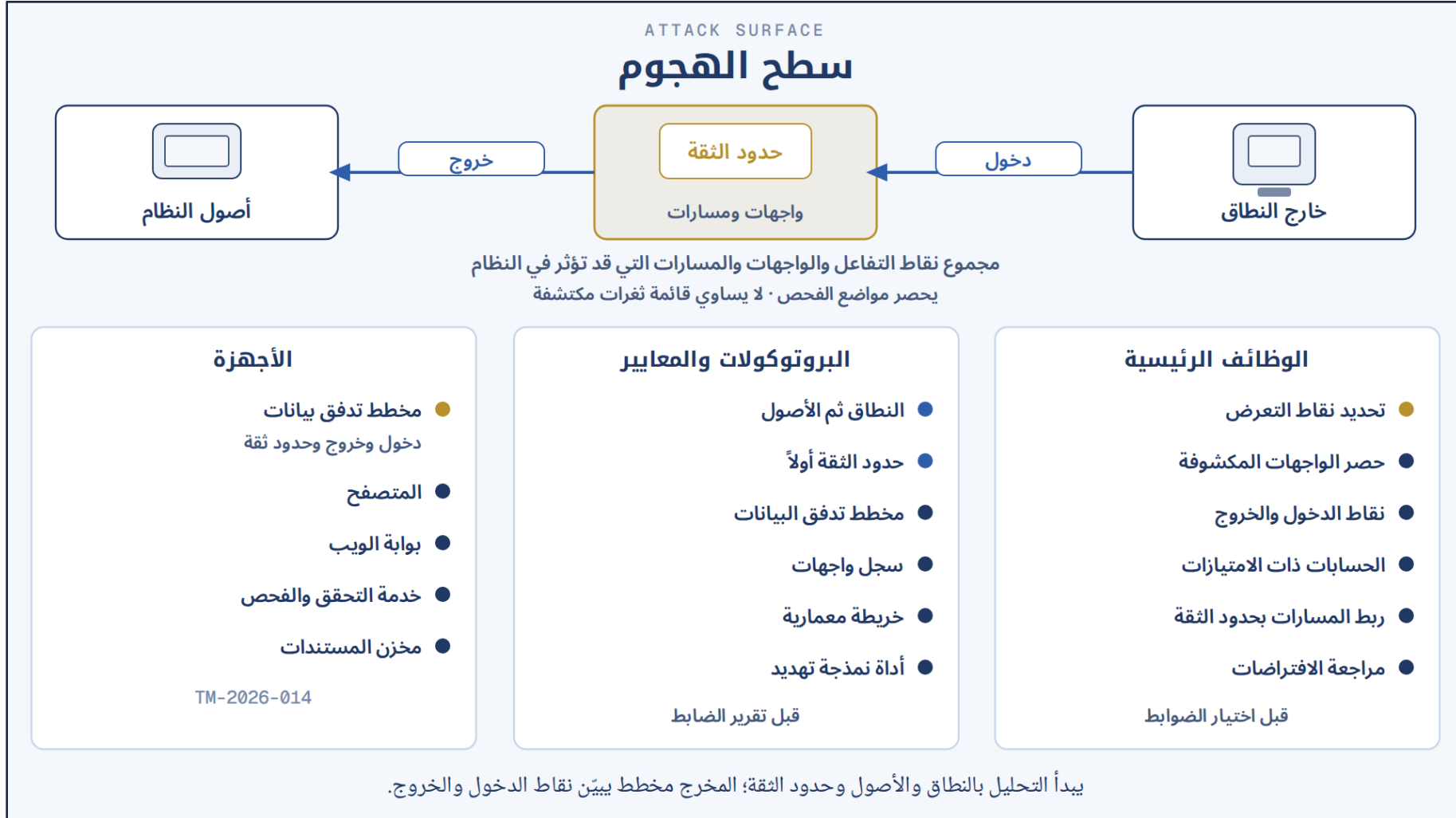


سطح الهجوم (Attack Surface)

- ◀ سطح الهجوم هو مجموع نقاط التفاعل والواجهات والمسارات التي قد تؤثر في النظام.
- ◀ وظيفته حصر المواضيع التي تستحق فحصاً قبل اختيار الضوابط، ولا يساوي قائمة ثغرات مكتشفة.
- ◀ **الوظيفة:** تحديد نقاط التعرض المرتبطة بالواجهات والتدفقات والاعتماديات.
- ◀ **المسؤوليات:** حصر الواجهات المكشوفة، أي نقاط الاستقبال أو العرض، تحديد نقاط الدخول والخروج، أي انتقالات الطلبات والملفات، مراجعة الحسابات ذات الامتيازات، أي القدرات الحساسة، ربط المسارات بحدود الثقة، أي مواضيع اختلاف الصلاحيات، مراجعة الافتراضات، أي ما يفترضه التصميم عن المكونات.
- ◀ **القواعد:** يبدأ التحليل بالنطاق والأصول وحدود الثقة قبل تقرير الضابط.
- ◀ **الأدوات:** مخطط تدفق البيانات، سجل واجهات، خريطة معمارية، أداة نمذجة تهديد.
- ◀ **المخرج:** مخطط تدفق بيانات يبين نقاط الدخول والخروج وحدود الثقة.
- ◀ **مثال:** تشمل نقاط التحليل في TM-2026-014 المتصفح وبوابة الويب وخدمة التحقق وخدمة الفحص ومخزن المستندات.



سطح الهجوم (Attack Surface) (الشكل)





نشاط تطبيقي، تحديد حدود الثقة



- ◀ الزمن: 25 دقيقة.
- ◀ اقرأ مكونات خدمة رفع المستندات الآتية: متصفح العميل، بوابة الويب، خدمة تحقق خارجية عبر نفاذ، خدمة فحص الملفات، قاعدة بيانات الطلبات، ومخزن المستندات الداخلي.
- ◀ حدد ثلاثة انتقالات بيانات تختلف فيها الثقة أو الصلاحية.
- ◀ اكتب بجانب كل انتقال ضابطاً تصميمياً أولاً وسبب اختياره.
- ◀ راجع إجابتك بمطابقة الأصل المتأثر ونقطة الدخول ومتطلب الحماية.



- ◀ الانتقال الأول يقع بين متصفح العميل وبوابة الويب، ويحتاج تحققاً خادماً من المدخلات والجلسة.
- ◀ الانتقال الثاني بين بوابة الويب وخدمة التحقق الخارجية عبر نفاذ، ويحتاج توثيقاً واضحاً للهوية والاستجابة.
- ◀ الانتقال الثالث بين المنطقة المعزولة والشبكة الداخلية، ويحتاج تفويضاً دقيقاً وتقييداً لتدفقات البيانات وتسجيل العمليات الحساسة.



- ◀ نموذج التهديد ممارسة منظمة للنظر إلى النظام من منظور مهاجم محتمل لتحديد المخاطر ومعالجتها.
- ◀ يبدأ بالنطاق والأصول والحدود، ولا يقتصر على قائمة ثغرات.
- ◀ **الوظيفة:** استباق مشكلات التصميم قبل اتساع سطح الهجوم، بتحويل مكونات النظام وتدفقاته إلى عناصر قابلة للفحص.
- ◀ **المسؤوليات:** تحديد النطاق، أي الخدمة المشمولة، رسم النظام، أي الكيانات والتدفقات، تحديد الأصول والحدود، أي ما يحميه التصميم ومواضع اختلاف الثقة، تحديد التهديدات، أي ربط السيناريو بالفئة، اختيار المعالجة، أي ضابط ومالك وموعد، مراجعة النتائج، أي تحديثها عند تغير التصميم.
- ◀ المناهج: STRIDE، PASTA، شجرة الهجوم.
- ◀ **الأدوات:** مخطط تدفق البيانات، قالب STRIDE، سجل مخاطر، جدول قرارات.
- ◀ **المخرج:** وثيقة تتضمن النطاق والتهديدات والقرارات والمخاطر المتبقية.
- ◀ **مثال:** يحدد TM-2026-014 خدمة رفع المستندات ومكوناتها وتدفقات بياناتها ومتطلبات الحماية.



نموذج التهديد (Threat Model) (تابع)

مرحلة العمل	مخرجها في TM-2026-014
تحديد النطاق	خدمة رفع مستندات العملاء
تحديد التهديدات	فئات STRIDE للعناصر والتدفقات
تحديد المعالجة	ضوابط وسجل مخاطر
تقييم العمل	مراجعة النموذج عند تغير المعمارية



نموذج التهديد (Threat Model) (تابع)



◀ مثال محلول:

◀ **المعطيات:** يضم النموذج TM-2026-014 كيانين خارجيين وخمسة مكونات داخلية وثلاثة حدود ثقة وستة أصول.

◀ الخطوات:

1. نحدد نطاق الخدمة بأنه رفع المستندات ومراجعتها، فلا نضم خدمات غير مذكورة.
 2. نحسب عناصر التحليل الرئيسة: $2 + 5 = 7$ عناصر.
 3. نربط الحدود الثلاثة بالأصول الستة قبل تطبيق STRIDE على التدفقات.
- ◀ **النتائج:** ينتج نموذج تهديد محدد النطاق يضم 7 عناصر و3 حدود و6 أصول، ويتيح تسجيل تهديد وقرار معالجة لكل حالة ذات صلة.

مثال محلول على النموذج، إعداد نموذج التهديد

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

النموذج: نموذج تحديد نطاق التهديد

معرف النموذج:

تاريخ الإعداد:

الخدمة محل التحليل:

غرض الخدمة:

الكيانات الخارجية:

مكونات المعالجة الداخلية:

تدفقات البيانات:

حدود الثقة:

الأصول المعلوماتية:

متطلبات الحماية:

نطاق الالتزام:

يستخدم هذا النموذج مخططاً لورقة تصنيف STRIDE وسجل المخاطر المرتبطتين بالمعرفات R-01 إلى R-06.

المسؤول

مقدم الطلب

الاعتماد

مستند تعليمي إلكتروسي، الأسماء والأرقام غير حقيقية

- المعطيات: تحليل الشركة خدمة رفع مستندات العملاء ضمن منصة رقمية سحابية.
- تستقبل الخدمة مستندات العملاء وتتحقق من نوعها ثم تخزينها لمراجعة الموظفين المخولين.
- المطلوب تعبئة نموذج تهديد يحدد نطاق الخدمة والمكونات وحدود الثقة والأصول ومتطلبات الحماية، تمهيداً لتطبيق نموذج STRIDE وتحليل المخاطر.

الخطوة 1 من 4: توثيق هوية النموذج ونطاق الخدمة

شركة الحلول التقنية والخدمات الرقمية تطوير وإدارة المنصات الرقمية والخدمات السحابية جازان - المملكة العربية السعودية الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000 هاتف: 0500000000		النموذج: نموذج لتحديد نطاق التهديد
نموذج تحديد نطاق التهديد		
معرف النموذج:	TM-2026-014	
تاريخ الإعداد:	2026-03-16	
الخدمة محل التحليل:	خدمة رفع مستندات العملاء ضمن منصة رقمية سحابية	
غرض الخدمة:		
الكيانات الخارجية:		
مكونات المعالجة الداخلية:		
تدفقات البيانات:		
حدود الثقة:		
الأصول المعلوماتية:		
متطلبات الحماية:		
نطاق الالتزام:		
يستعمل هذا النموذج مدخلاً لورقة تصنيف STRIDE وسجل المخاطر المرتبطتين بالمعرفات R-01 إلى R-06.		
مقدم الطلب	المسؤول	الاعتماد
مستند تعليمي انتراسي، الأسماء والأرقام غير حقيقية		

- يدون النموذج المعرف TM-2026-014 وتاريخ الإعداد 2026-03-16، ثم يحدد خدمة رفع مستندات العملاء ضمن منصة رقمية سحابية.
- يثبت هذا الجزء نطاق التحليل ويمنع خلطه بخدمات أخرى.
- النتاج الجزئي هو نموذج محدد الهوية والخدمة، يمكن لفريق التصميم مراجعته وتحديثه عند تغير المعمارية أو الافتراضات.

الخطوة 2 من 4: تحديد الغرض والكيانات والمكونات

شركة الحلول التقنية والخدمات الرقمية تطوير وإدارة المنصات الرقمية والخدمات السحابية جازان، المملكة العربية السعودية الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000 هاتف: 0500000000		النموذج: نموذج تحديد نطاق التهديد
نموذج تحديد نطاق التهديد		
معرف النموذج:	TM-2026-014	
تاريخ الإعداد:	2026-03-16	
الخدمة محل التحليل:	خدمة رفع مستندات العملاء ضمن منصة رقمية سحابية	
غرض الخدمة:	استقبال مستندات العملاء والتحقق من نوعها وتخزينها لإتاحة مراجعتها للموظفين المخولين.	
الكيانات الخارجية:	العميل عبر المتصفح، وخدمة تحقق خارجية عبر نفاذ.	
مكونات المعالجة الداخلية:	بوابة الويب في منطقة معزولة، خدمة فحص الملفات، واجهة إدارة الموظفين، قاعدة بيانات الطلبات، ومخزن مستندات داخلي.	
تدفقات البيانات:		
حدود الثقة:		
الأصول المعلوماتية:		
متطلبات الحماية:		
نطاق الالتزام:		
يستعمل هذا النموذج مدخلاً لورقة تصنيف STRIDE وسجل المخاطر المرتبطتين بالمعرفات R-01 إلى R-06.		
مقدم الطلب	المسؤول	الاعتماد
مستند تعليمي اقتراسي، الأسماء والأرقام غير حقيقية		

- ◀ يدون غرض الخدمة، وهو استقبال المستندات والتحقق من نوعها وتخزينها لمراجعة الموظفين المخولين.
- ◀ ثم يميز العميل عبر المتصفح وخدمة تحقق خارجية عبر نفاذ عن بوابة الويب وخدمة الفحص وواجهة الإدارة وقاعدة البيانات والمخزن الداخلي.
- ◀ الناتج الجزئي هو قائمة مكونات تمثل عناصر التحليل في نموذج التهديد.

الخطوة 3 من 4: توثيق التدفقات والحدود والأصول

شركة الحلول التقنية والخدمات الرقمية تطوير وإدارة المنصات الرقمية والخدمات السحابية جازان، المملكة العربية السعودية الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000 هاتف: 0500000000		النموذج: تحديد نطاق التهديد
نموذج تحديد نطاق التهديد		
معرف النموذج: TM-2026-014		
تاريخ الإعداد: 2026-03-16		
الخدمة محل التحليل: خدمة رفع مستندات العملاء ضمن منصة رقمية سحابية		
غرض الخدمة: استقبال مستندات العملاء والتحقق من نوعها وتخزينها لإتاحة مراجعتها للموظفين المخولين.		
الكيانات الخارجية: العميل عبر المتصفح، وخدمة تحقق خارجية عبر نفاذ.		
مكونات المعالجة الداخلية: بوابة الويب في منطقة معزولة، خدمة فحص الملفات، واجهة إدارة الموظفين، قاعدة بيانات الطلبات، ومخزن مستندات داخلي.		
تدفقات البيانات: يرسل العميل ملفاً وبيانات وصفية إلى بوابة الويب. ترسل البوابة طلب تحقق إلى الخدمة الخارجية. يمر الملف إلى خدمة الفحص ثم إلى مخزن المستندات، وتسجل قاعدة البيانات حالة الطلب وسجل التدقيق.		
حدود الثقة: الحد الأول بين متصفح العميل وبوابة الويب. الحد الثاني بين بوابة الويب وخدمة التحقق الخارجية. الحد الثالث بين منطقة البوابة المعزولة والشبكة الداخلية التي تضم قاعدة البيانات ومخزن المستندات.		
الأصول المعلوماتية: ملفات الهوية والشهادات، بيانات الطلبات، رموز الجلسات، سجلات التدقيق، حسابات الموظفين، وإعدادات التخزين السحابي.		
متطلبات الحماية:		
نطاق الالتزام:		
يستعمل هذا النموذج مدخلاً لورقة تصنيف STRIDE وسجل المخاطر المرتبطين بالمعرفات R-01 إلى R-06.		
مقدم الطلب	المسؤول	الاعتماد
مستند تعليمي إلكتروسي، الأسماء والأرقام غير حقيقية		

- يوثق النموذج تدفق الملف والبيانات الوصفية من العميل إلى البوابة، ثم إلى الفحص والتخزين، مع تسجيل حالة الطلب وسجل التدقيق.
- وتحدد الحدود الثلاثة انتقالات الثقة، لأن كل انتقال يربط جهتين تختلفان في الصلاحية أو موقع المعالجة.
- كما تسجل الأصول، ومنها الملفات ورموز الجلسات، حتى يربط التحليل كل تهديد بأصل متأثر ومتطلب حماية واضح.

الخطوة 3 من 4: توثيق التدفقات والحدود والأصول (تابع)

◀ مثال محلول:

◀ **المعطيات:** يحتوي النموذج TM-2026-014 على كيانين خارجيين، وخمسة مكونات داخلية، وثلاثة حدود ثقة، وستة أصول معلوماتية.

◀ الخطوات:

1. نعد الكيانات الخارجية: العميل عبر المتصفح وخدمة التحقق الخارجية، فيكون العدد 2.
2. نعد المكونات الداخلية: بوابة الويب، خدمة الفحص، واجهة الإدارة، قاعدة البيانات، ومخزن المستندات، فيكون العدد 5.
3. نحدد الحدود الثلاثة الموثقة، ثم نربط الحد الثالث بملفات الهوية والشهادات ومخزن المستندات.

◀ **النتائج:** نطاق التحليل يضم $2 + 5 = 7$ عناصر رئيسية و3 حدود ثقة و6 أصول.

◀ يصبح تدفق الملف عبر الحد الثالث نقطة مناسبة لفحص الإفشاء غير المصرح به ورفع الامتيازات.

- تسجل متطلبات الحماية، وهي سرية المستندات وتكامل البيانات ومنع الوصول غير المصرح وإتاحة الخدمة وإثبات العمليات.
- ويرتبط نطاق الالتزام بحماية البيانات الشخصية ومراجعة الضوابط الأساسية للأمن السيراني.
- الناتج هو نموذج تهديد مكتمل يربط عناصر النظام بغايات الحماية، ويصبح مدخلاً منظماً لسجل التهديدات والمخاطر.**



STRIDE نموذج

- ◀ نموذج STRIDE تصنيف منهجي للتهديدات في ست فئات مرتبة: انتحال الهوية، التلاعب بالبيانات، التنصل، الإفشاء غير المصرح به، رفض الخدمة، ورفع الامتيازات.
- ◀ **الوظيفة:** فحص العناصر والتدفقات وحدود الثقة بصورة منظمة.
- ◀ **المسؤوليات:** تفكيك النظام، فحص العناصر، تسجيل الفئة، ربطها بالأصل، اقتراح ضابط ومعالجة.
- ◀ **القواعد:** STRIDE منهج تصنيف، وليس بروتوكول اتصال أو معيار امتثال.
- ◀ **الأدوات:** مخطط تدفق البيانات، قالب STRIDE، أداة نمذجة تهديد، سجل قرارات.
- ◀ **المخرج:** سجل يربط العنصر بفئة التهديد والأثر والضابط.
- ◀ **مثال:** يصنف إرسال رمز جلسة مسروق إلى بوابة الويب ضمن انتحال الهوية.



نموذج STRIDE (الشكل)





جدول STRIDE وخصائص الحماية



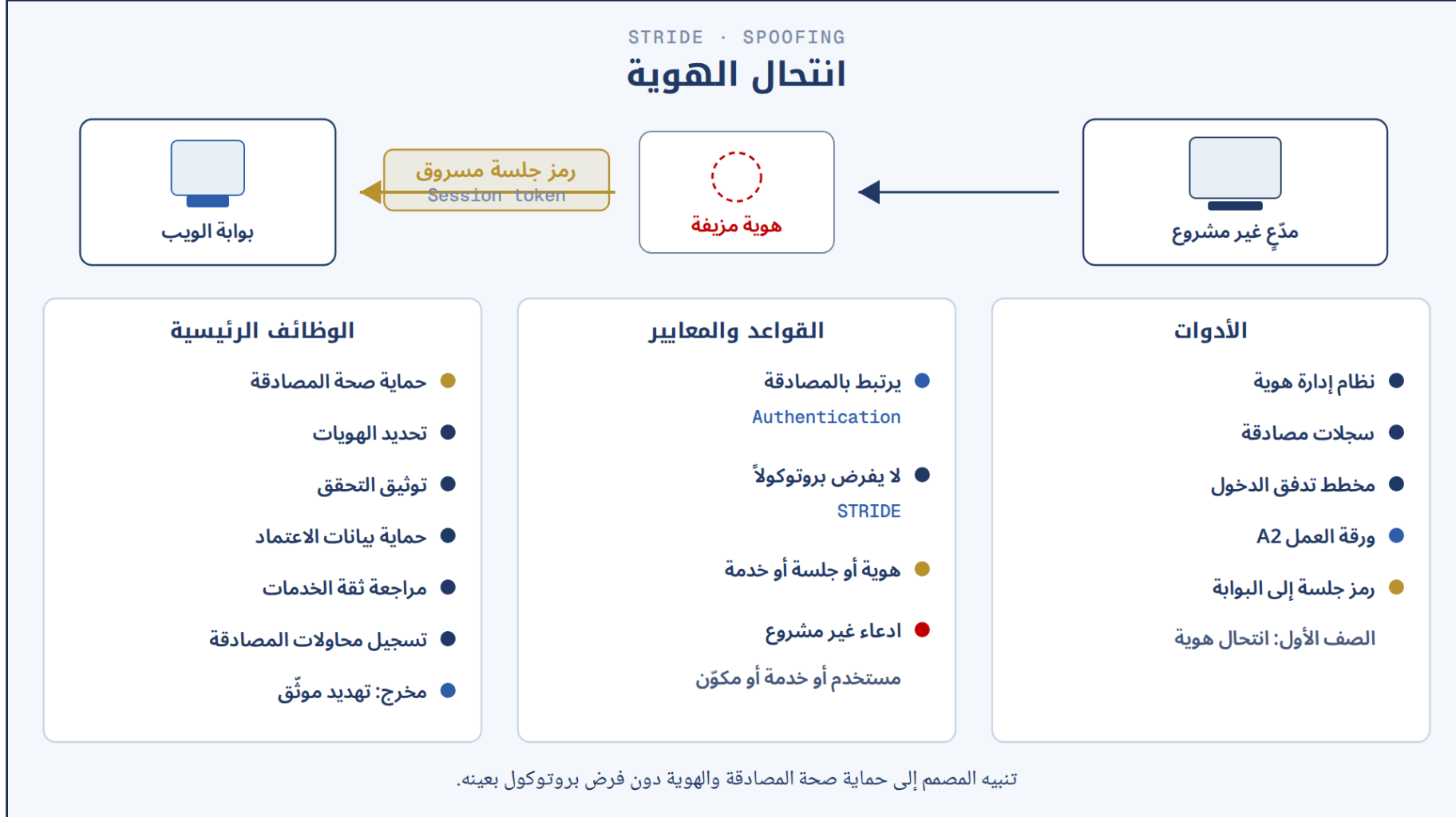
فئة التهديد	الخاصية المتأثرة	مثال من خدمة رفع المستندات	ضابط تصميمي
انتحال الهوية	المصادقة	رمز جلسة مسروق	تحقق من الجلسة ومصادقة مناسبة
التلاعب بالبيانات	تكامل البيانات	تعديل رقم الطلب	HTTPS وتحقق خادمي من المدخلات
التنصل	المحاسبة	إنكار عملية رفع	سجل تدقيق مناسب
الإفشاء غير المصرح به	السرية	رابط تنزيل غير محمي	تفويض خادمي وتشفير
رفض الخدمة	التوافر	ملفات كبيرة ومتكررة	ضبط الحجم والمعدل
رفع الامتيازات	التفويض	خدمة فحص واسعة الصلاحية	أقل الامتيازات وعزل الفحص



- ◀ انتحال الهوية تهديد يتمثل في ادعاء أو تقليد هوية مستخدم أو خدمة أو مكون بصورة غير مشروعة.
- ◀ **الوظيفة:** تنبيه المصمم إلى حماية صحة المصادقة والهوية.
- ◀ **المسؤوليات:** تحديد الهويات، توثيق التحقق، حماية بيانات الاعتماد، مراجعة ثقة الخدمات، تسجيل محاولات المصادقة.
- ◀ **القواعد:** يرتبط بالمصادقة، ولا يفرض STRIDE بروتوكولاً بعينه.
- ◀ **الأدوات:** نظام إدارة هوية، سجلات مصادقة، مخطط تدفق تسجيل الدخول.
- ◀ **المخرج:** تهديد موثق مرتبط بهوية أو جلسة أو خدمة.
- ◀ **مثال:** الصف الأول في ورقة العمل A2 يصنف رمز الجلسة المسروق المرسل إلى بوابة الويب بأنه انتحال هوية.



انتحال الهوية (Spoofing) (الشكل)





- ◀ التلاعب بالبيانات هو تعديل غير مصرح به للبيانات أو الشفرة أو الرسائل أو الإعدادات.
- ◀ **الوظيفة:** حماية تكامل البيانات وسلامة معالجة النظام.
- ◀ **المسؤوليات:** تحديد البيانات الحساسة، تحديد التخزين والنقل، تعيين ضوابط سلامة، تسجيل التغييرات، التحقق من المعالجة.
- ◀ **القواعد:** يرتبط بتكامل البيانات، ولا يحدد STRIDE تقنية إلزامية واحدة.
- ◀ **الأدوات:** سجل تدقيق، آلية تحقق من التكامل، مراجعة تغييرات، مخطط تدفقات البيانات.
- ◀ **المخرج:** متطلب حماية لتكامل أصل أو تدفق.
- ◀ **مثال:** يعدل السيناريو الثاني في A2 بيانات وصفية للملف أو رقم الطلب أثناء انتقاله من المتصفح إلى البوابة.



التلاعب بالبيانات (Tampering) (الشكل)



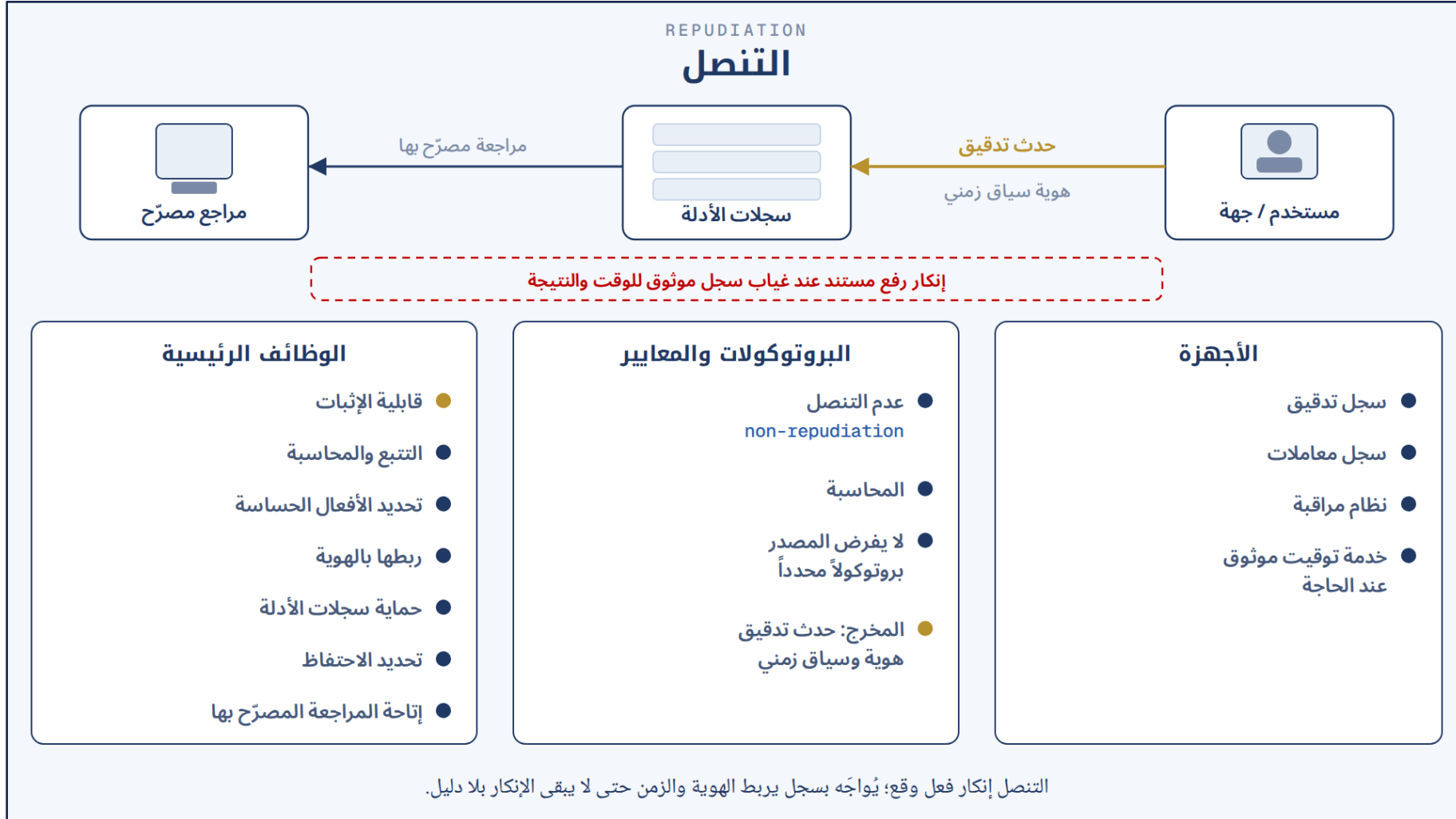


التنصل (Repudiation)

- ◀ التنصل هو إنكار مستخدم أو جهة تنفيذ فعل أو معاملة أو تغيير وقع في النظام.
- ◀ **الوظيفة:** توجيه التصميم نحو قابلية الإثبات والتتبع والمحاسبة.
- ◀ **المسؤوليات:** تحديد الأفعال الحساسة، ربطها بالهوية، حماية سجلات الأدلة، تحديد الاحتفاظ، إتاحة المراجعة المصرح بها.
- ◀ **القواعد:** يتعلق بعدم التنصل والمحاسبة، ولا يفرض المصدر بروتوكولاً محدداً.
- ◀ **الأدوات:** سجل تدقيق، سجل معاملات، نظام مراقبة، خدمة توقيت موثوق عند الحاجة.
- ◀ **المخرج:** حدث تدقيق يتضمن هوية وسياًقاً زمنياً.
- ◀ **مثال:** يصف الصف الثالث في A2 عميلاً ينكر رفع مستند خاطئ عند غياب سجل موثوق لوقت الرفع ونتيجته.



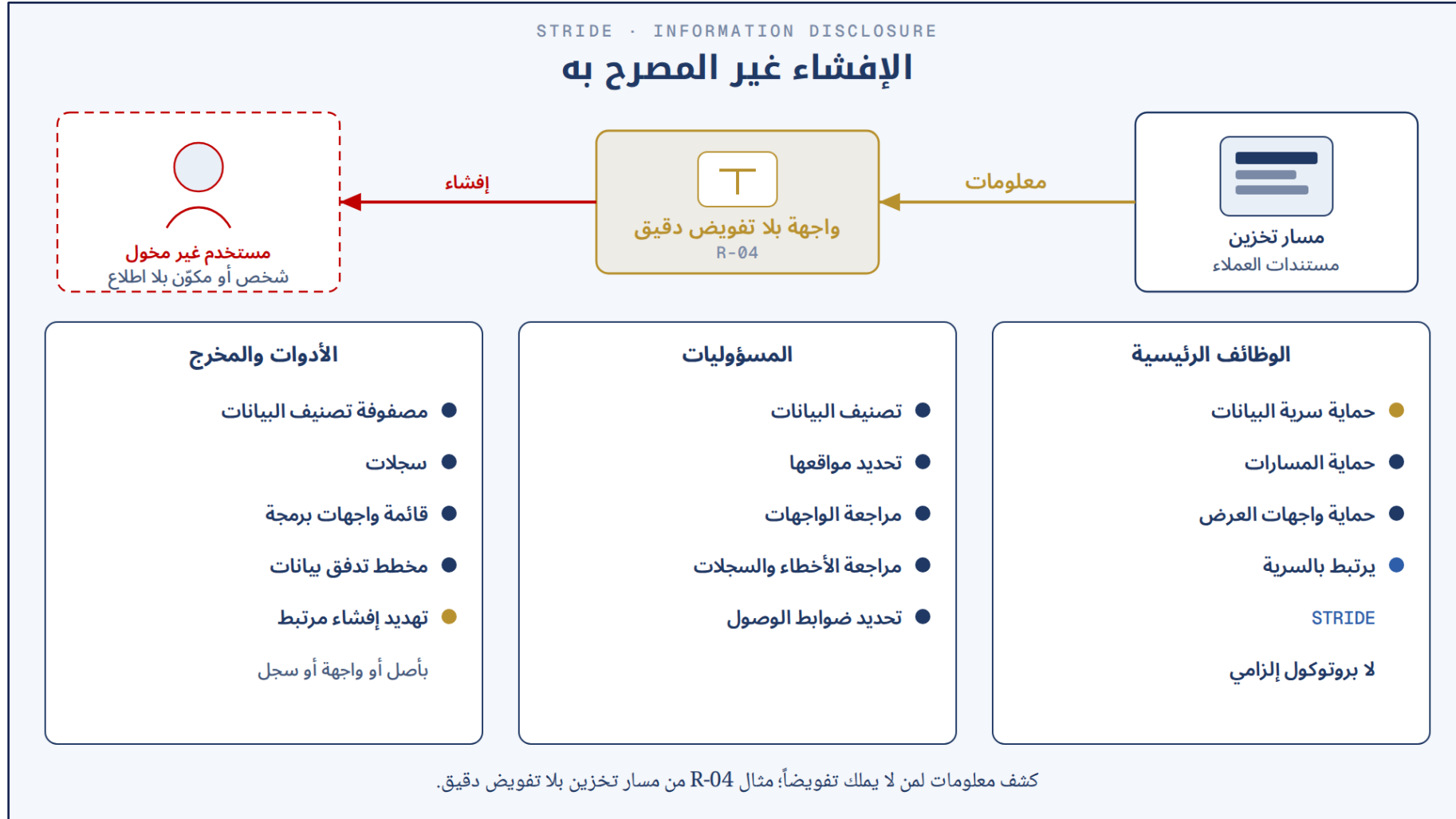
التنصل (Repudiation) (الشكل)





- الإفشاء غير المصرح به هو كشف معلومات لشخص أو مكون لا يملك تفويض الاطلاع عليها.
- الوظيفة:** حماية سرية البيانات ومساراتها وواجهات عرضها.
- المسؤوليات:** تصنيف البيانات، تحديد مواقعها، مراجعة الواجهات، مراجعة الأخطاء والسجلات، تحديد ضوابط الوصول.
- القواعد:** يرتبط بالسرية، ولا يفرض STRIDE بروتوكولاً إلزامياً.
- الأدوات:** مصفوفة تصنيف البيانات، سجلات، قائمة واجهات برمجة، مخطط تدفق بيانات.
- المخرج:** تهديد إفشاء مرتبط بأصل أو واجهة أو سجل.
- مثال:** يمثل R-04 وصول مستخدم غير مخول إلى مستندات العملاء من مسار تخزين لا يفرض تفويضاً دقيقاً.

الإفشاء غير المصرح به (Information Disclosure) (الشكل)



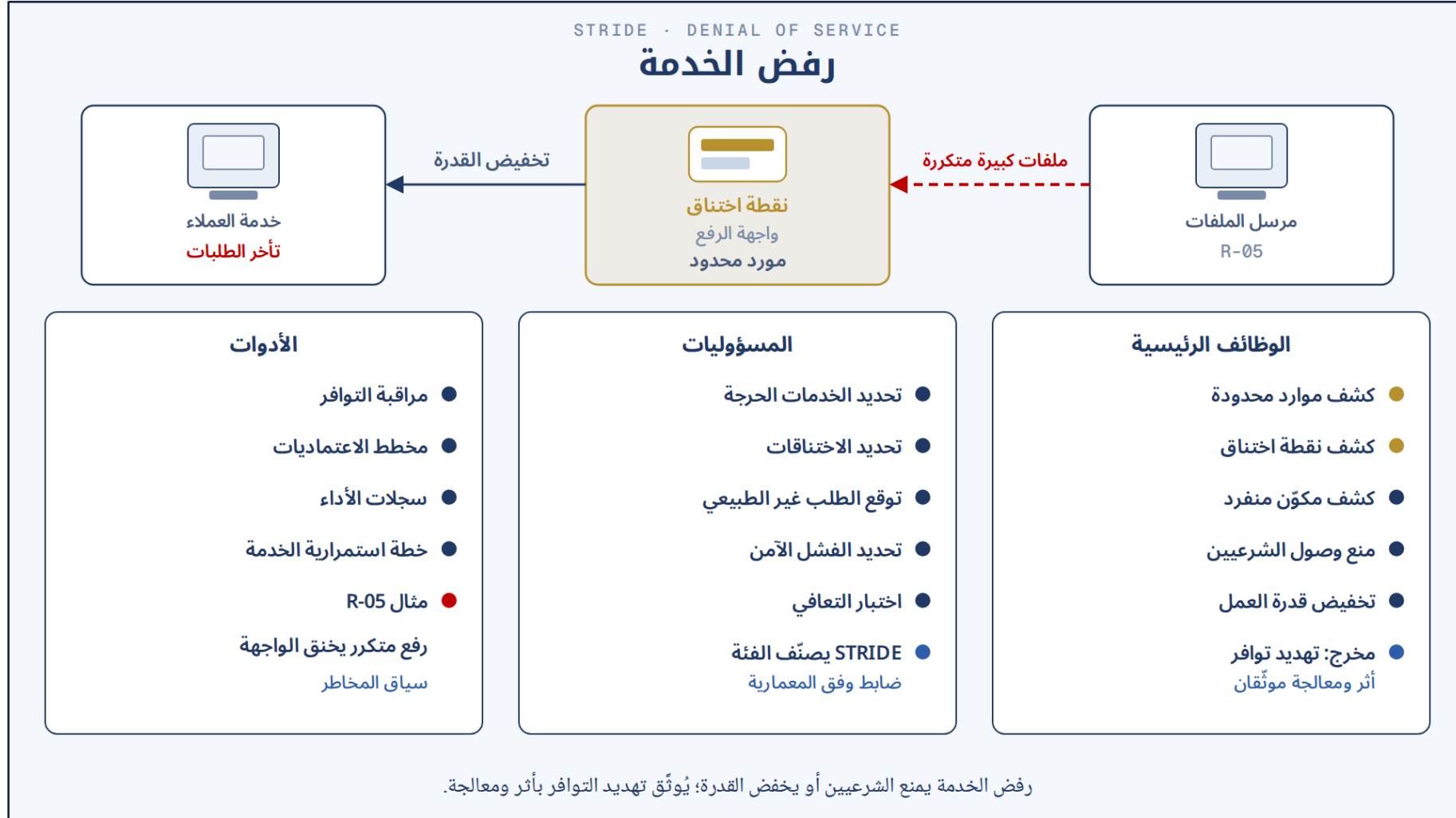


رفض الخدمة (Denial of Service)

- ◀ رفض الخدمة هو منع المستخدمين الشرعيين من الوصول إلى خدمة أو تخفيض قدرتها على العمل.
- ◀ **الوظيفة:** كشف الاعتماد على موارد محدودة أو نقطة اختناق أو مكون منفرد.
- ◀ **المسؤوليات:** تحديد الخدمات الحرجة، تحديد الاختناقات، توقع الطلب غير الطبيعي، تحديد الفشل الآمن، اختبار التعافي.
- ◀ **القواعد:** STRIDE يصنف الفئة، واختيار الضابط يتبع معمارية النظام وسياق المخاطر.
- ◀ **الأدوات:** مراقبة التوافر، مخطط الاعتماديات، سجلات الأداء، خطة استمرارية الخدمة.
- ◀ **المخرج:** تهديد توافر موثق بأثر ومعالجة.
- ◀ **مثال:** يمثل R-05 إرسال ملفات كبيرة ومتكررة إلى واجهة الرفع، بما يؤدي إلى تأخر معالجة طلبات العملاء.



(الشكل) (Denial of Service) رفض الخدمة



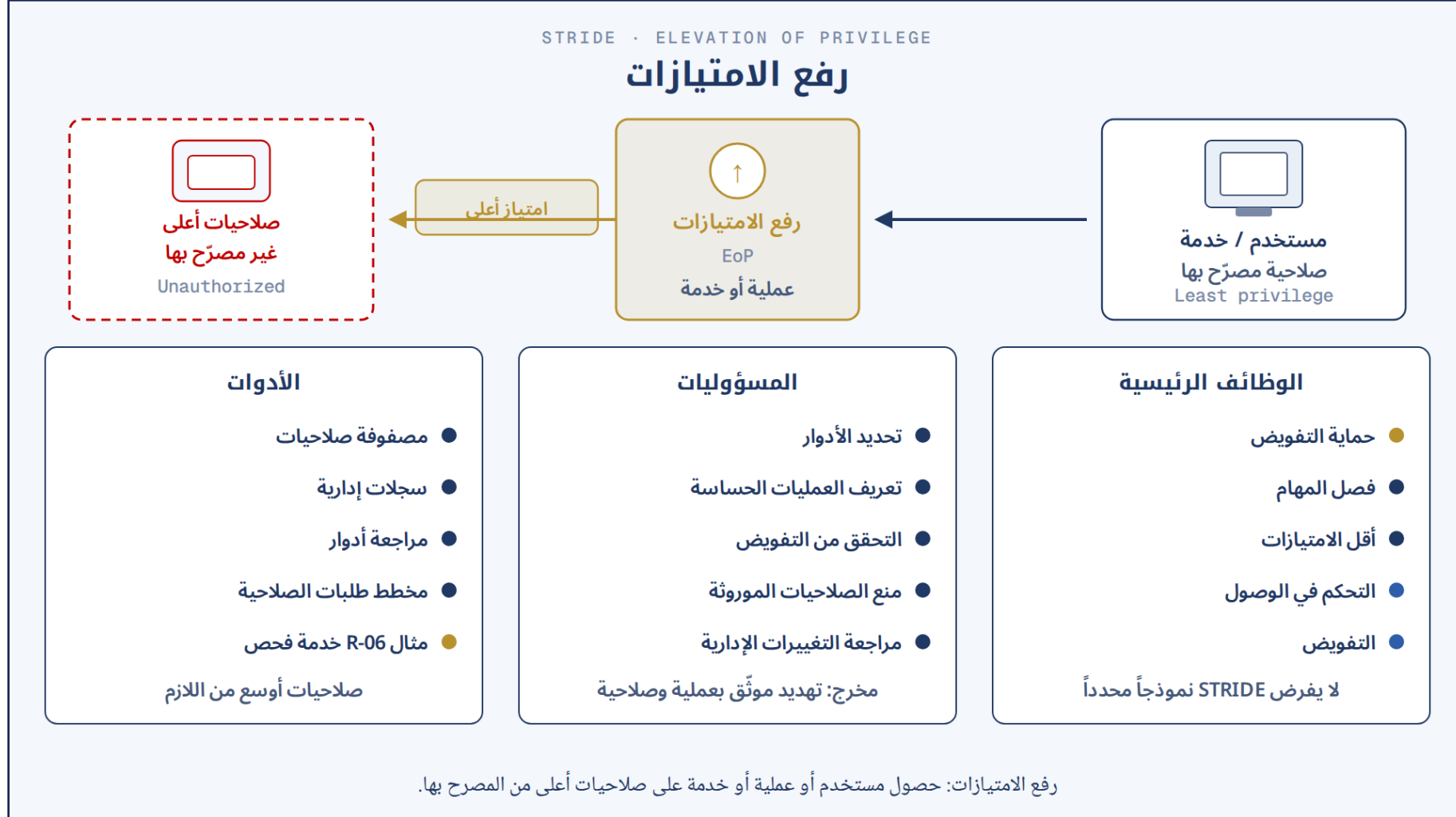


رفع الامتيازات (Elevation of Privilege)

- ◀ رفع الامتيازات هو حصول مستخدم أو عملية أو خدمة على صلاحيات أعلى من المصرح بها.
- ◀ **الوظيفة:** حماية التفويض وفصل المهام وأقل الامتيازات.
- ◀ **المسؤوليات:** تحديد الأدوار، تعريف العمليات الحساسة، التحقق من التفويض، منع الصلاحيات الموروثة، مراجعة التغييرات الإدارية.
- ◀ **القواعد:** يرتبط بالتحكم في الوصول والتفويض، ولا يفرض STRIDE نموذج وصول محدداً.
- ◀ **الأدوات:** مصفوفة صلاحيات، سجلات إدارية، مراجعة أدوار، مخطط طلبات الصلاحية.
- ◀ **المخرج:** تهديد موثق بعملية وصلاحية غير مشروعة محتملة.
- ◀ **مثال:** يمثل R-06 خدمة فحص ملفات تعمل بصلاحيات أوسع من اللازم ويمكن أن تتأثر بملف خبيث.



(الشكل) رفع الامتيازات (Elevation of Privilege)



ورقة عمل STRIDE المكتملة



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000000 - السجل التجاري: 1010000000
هاتف: 0500000000

ورقة العمل: لخدمة رفع المستندات STRIDE ورقة تحليل

ورقة تحليل STRIDE لخدمة رفع المستندات

#	السيناريو	فئة التهديد والتحليل	الضابط المقترح
1	يرسل مهاجم رمز جلسة مسروقاً إلى بوابة الويب ليتظاهر بأنه العميل الذي رفع المستندات.	انتحال الهوية (Spoofing)، الخطر هو قبول هوية غير صحيحة والوصول إلى مستندات العميل أو تنفيذ عمليات باسمه.	مصادقة متعددة العوامل عند الحاجة، ربط الجلسة بخصائص أمانة، انتهاء قصير لرمز الجلسة، والتحقق من الجلسات غير المعتادة.
2	يعدل مهاجم البيانات الوصفية للملف أثناء انتقالها من المتصفح إلى البوابة، فيغير نوع المستند أو رقم الطلب.	التلاعب بالبيانات (Tampering)، يتأثر تكامل البيانات لأن محتوى الطلب أو وصفه قد يتغير قبل المعالجة.	استخدام HTTPS، التحقق من صحة المدخلات في الخادم، حفظ بصمة للملف، ومنع اعتماد نوع الملف المرسل من المتصفح وحده.
3	ينكر عميل أنه رفع مستنداً بعد أن يكشف أن النسخة المرفوعة غير صحيحة.	التنصل (Repudiation)، لا يمكن إثبات العملية إذا غابت سجلات تدقيق موثوقة تتضمن وقت العملية ومعرف الجلسة ونتيجة الرفع.	تسجيل تدقيق غير قابل للتعديل نسبياً، توثيق وقت الرفع ومعرف الطلب، وربط السجل بنتيجة الفحص.
4	يكشف مستخدم غير مخول مساراً مباشراً في التخزين يتيح قراءة مستندات عملاء آخرين.	الإفشاء غير المصرح (Information Disclosure)، تتعرض البيانات الشخصية والمستندات السرية للكشف دون تفويض.	فرض تفويض على مستوى الخادم لكل طلب تنزيل، تشفير التخزين، روابط وصول مؤقتة، ومراجعة إعدادات مخزن المستندات.
5	يرسل مهاجم ملفات كبيرة ومتكررة إلى نقطة الرفع حتى تتأخر معالجة طلبات العملاء.	رفض الخدمة (Denial of Service)، تتأثر إتاحة خدمة الرفع وقد تتأخر عمليات الفحص والمعالجة المشروعة.	تحديد حجم الملفات ومعدل الطلبات، وضع طابور للمعالجة، مراقبة السعة، وتطبيق حماية مناسبة على واجهة الويب.
6	يرفع مهاجم ملفاً خبيثاً يستغل خدمة الفحص أو يحاول تنفيذ تعليمات على خادم المعالجة.	رفع الامتيازات (Elevation of Privilege)، قد ينتقل المهاجم من صلاحيات عميل عادي إلى صلاحيات خدمة أو مسؤول نظام.	فحص الملفات في بيئة معزولة، تشغيل خدمة الفحص بأقل الامتيازات، منع التنفيذ من مسار الرفع، وتحديث مكونات المعالجة.

تستند السيناريوهات إلى نطاق النموذج TM-2026-014، وتؤدي تقديرات المخاطر في الجدول الحسابي.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

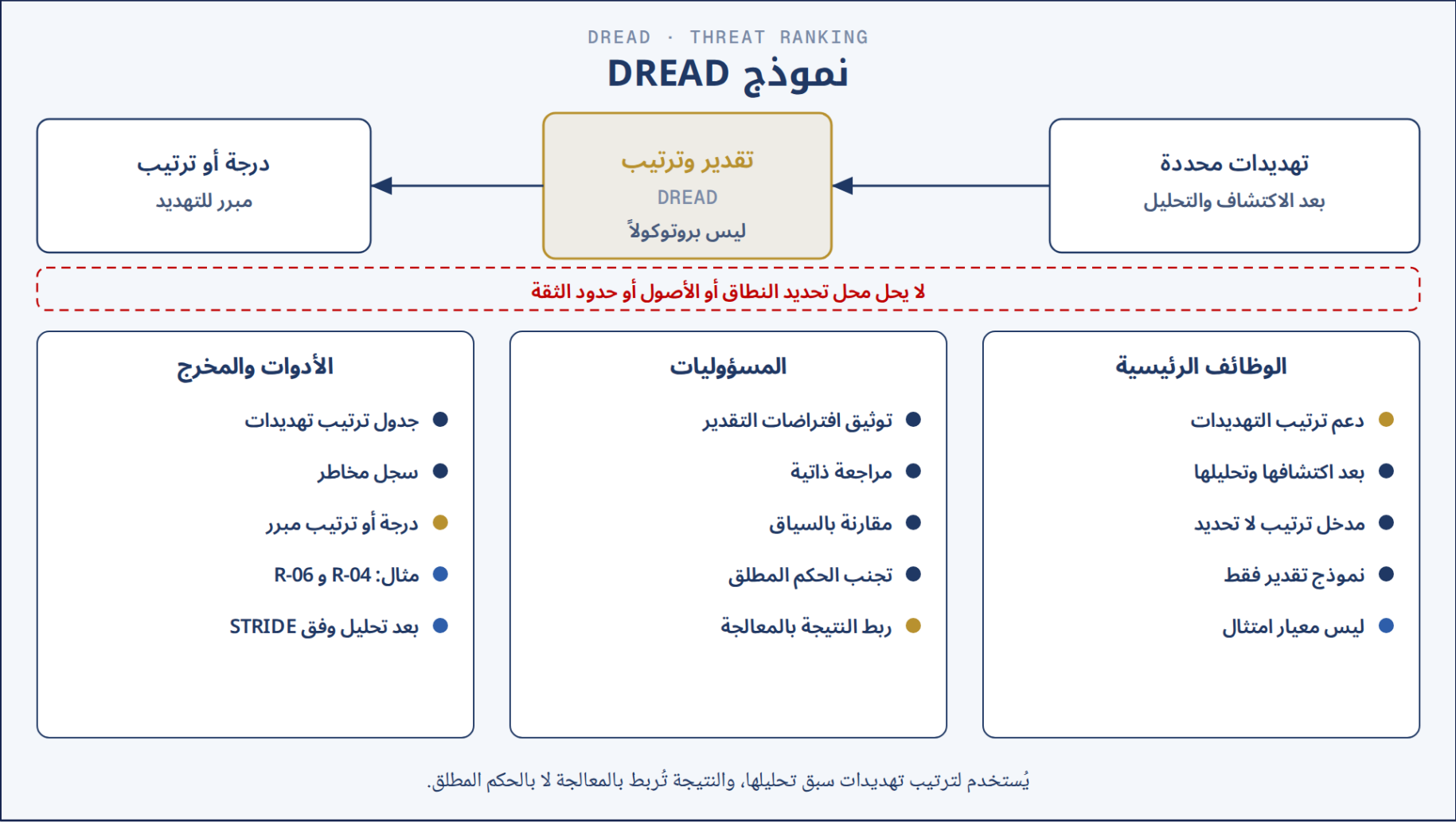
- أقرأ كل صف بوصفه سلسلة قران: سيناريو، فئة تهديد، أثر على خاصية أمنية، ثم ضابط مقترح.
- لاحظ أن السيناريو السادس لا يكفي بتصنيف رفع الامتيازات، بل يقترح عزل الفحص وتشغيل الخدمة بأقل الامتيازات ومنع التنفيذ من مسار الرفع وتحديث مكونات المعالجة.



- ◀ نموذج DREAD مدخل لترتيب تهديدات سبق تحديدها، ولا يحل محل تحديد النطاق أو الأصول أو حدود الثقة.
- ◀ **الوظيفة:** دعم ترتيب التهديدات بعد اكتشافها وتحليلها.
- ◀ **المسؤوليات:** توثيق افتراضات التقدير، مراجعة ذاتية، مقارنة بالسياق، تجنب الحكم المطلق، ربط النتيجة بالمعالجة.
- ◀ **القواعد:** DREAD نموذج تقدير، وليس بروتوكولاً أو معيار امتثال.
- ◀ **الأدوات:** جدول ترتيب تهديدات، سجل مخاطر.
- ◀ **المخرج:** درجة أو ترتيب مبرر للتهديد.
- ◀ **مثال:** يمكن استخدامه لترتيب R-04 و R-06 بعد تحليل خدمة رفع المستندات وفق STRIDE وسجل المخاطر.



نموذج DREAD (الشكل)

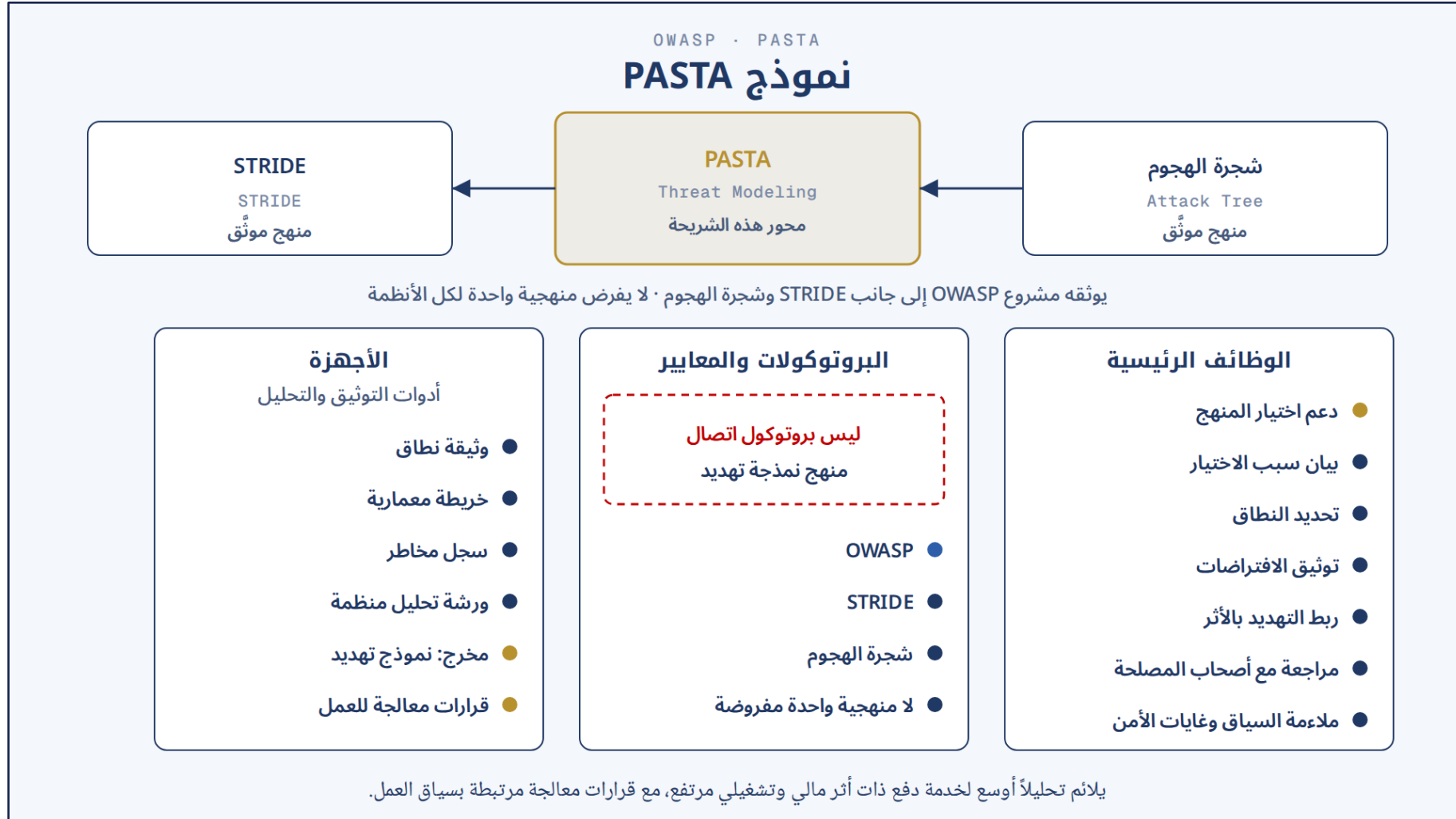




- ◀ نموذج PASTA أحد مناهج نمذجة التهديد التي يوثقها مشروع OWASP إلى جانب STRIDE وشجرة الهجوم.
- ◀ **الوظيفة:** دعم اختيار منهج يلائم سياق النظام وغايات الأمن واحتياجات العمل.
- ◀ **المسؤوليات:** بيان سبب الاختيار، تحديد النطاق، توثيق الافتراضات، ربط التهديد بالأثر، مراجعة المخرجات مع أصحاب المصلحة.
- ◀ **القواعد:** PASTA منهج نمذجة، وليس بروتوكول اتصال.
- ◀ **الأدوات:** وثيقة نطاق، خريطة معمارية، سجل مخاطر، ورشة تحليل منظمة.
- ◀ **المخرج:** نموذج تهديد وقرارات معالجة مرتبطة بسياق العمل.
- ◀ **مثال:** يلائم تحليلاً أوسع لخدمة دفع ذات أثر مالي وتشغيلي مرتفع. لا يفرض OWASP منهجية واحدة لكل الأنظمة.

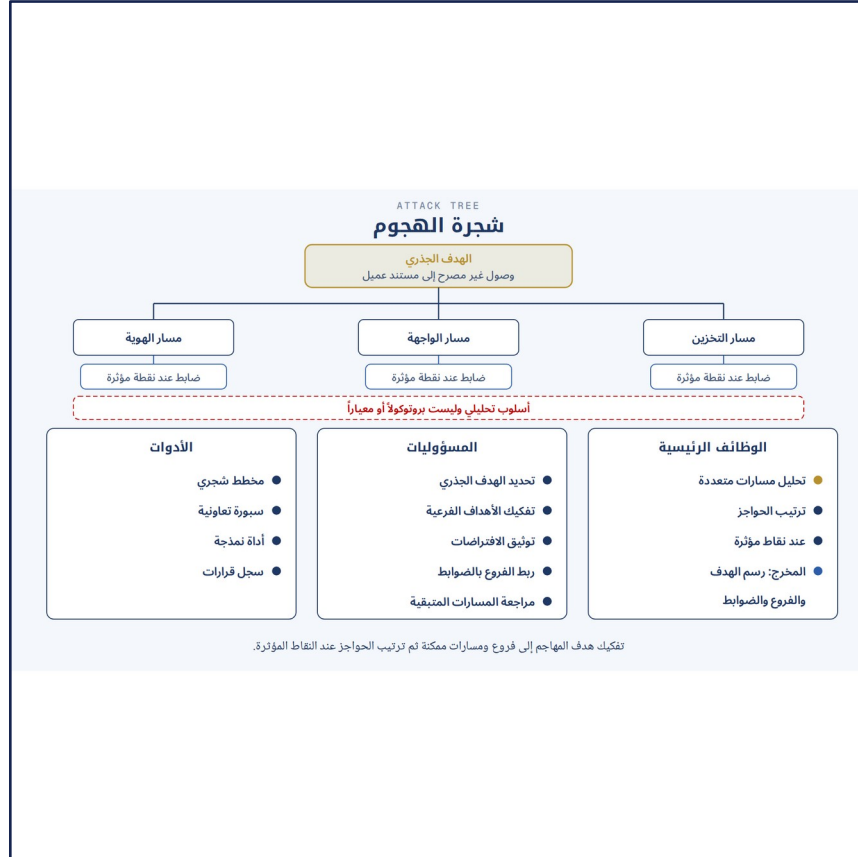


نموذج PASTA (الشكل)





شجرة الهجوم (Attack Tree)



شجرة الهجوم أسلوب يمثل هدف المهاجم في عقدة رئيسية، ثم يفككه إلى فروع ومسارات ممكنة للوصول إليه.

الوظيفة: تحليل مسارات متعددة وترتيب الحواجز عند نقاط مؤثرة.

المسؤوليات: تحديد الهدف الجذري، تفكيك الأهداف الفرعية، توثيق الافتراضات، ربط الفروع بالضوابط، مراجعة المسارات المتبقية.

القواعد: شجرة الهجوم أسلوب تحليلي وليست بروتوكولاً أو معياراً.

الأدوات: مخطط شجري، سبورة تعاونية، أداة نمذجة، سجل قرارات.

المخرج: رسم يوضح الهدف والفروع والضوابط.

مثال: يكون الهدف الوصول غير المصرح إلى مستند عميل، وتتفرع المسارات حول الهوية أو الواجهة أو التخزين.



نشاط تحليلي، تصنيف سيناريوهات STRIDE

- ◀ الزمن: 30 دقيقة.
- ◀ صنف السيناريوهات الآتية ضمن فئات STRIDE المناسبة: تعديل رقم الطلب في أثناء الإرسال، إنكار العميل رفع مستند، قراءة مستند من رابط عام، إرسال ملفات كبيرة متكررة، وتشغيل خدمة فحص بصلاحيات أوسع من اللازم.
- ◀ اذكر الخاصية الأمنية المتأثرة وضابطاً تصميمياً واحداً لكل سيناريو.
- ◀ برر التصنيف بربط السيناريو بالأصل وحد الثقة وراجع الإجابة وفق ورقة العمل.



- ◀ تعديل رقم الطلب هو تلاعب بالبيانات ويهدد تكامل البيانات، لأن البيانات تتغير قبل اعتمادها في الخادم، ويعالج بالتحقق الخادمي وبصمة الملف.
- ◀ إنكار الرفع هو تنصل، لأن المشكلة هي إثبات الفعل لا تغيير البيانات، ويحتاج سجل تدقيق مناسباً.
- ◀ الرابط العام إفشاء غير مصرح به، لأن مستخدماً غير مخول يقرأ مستنداً، ويحتاج تفويضاً خادماً.
- ◀ الملفات الكبيرة رفض خدمة، لأنها تستهلك قدرة المعالجة، ويحتاج تحديد الحجم والمعدل.
- ◀ الصلاحيات الواسعة تمثل رفع امتيازات، لأنها تمنح قدرة أعلى من المطلوب، وتحتاج عزل الفحص وأقل الامتيازات.



إجابة النشاط، تصنيف التهديدات (تابع)

الضابط	الخاصية المتأثرة	فئة STRIDE	السيناريو
HTTPS وتحقق خادمي من المدخلات	تكامل البيانات	التلاعب بالبيانات	تعديل رقم الطلب
سجل تدقيق	المحاسبة	التنصل	إنكار الرفع
تفويض خادمي	السرية	الإفشاء غير المصرح به	رابط عام لمستند
تحديد الحجم والمعدل	التوافر	رفض الخدمة	ملفات كبيرة متكررة
العزل وأقل الامتيازات	التفويض	رفع الامتيازات	خدمة فحص واسعة الصلاحية



إجابة النشاط، تصنيف التهديدات (تابع)

المطلوب

١. نربط تعديل رقم الطلب بتغيير غير مصرح به، فتكون الفئة التلاعب بالبيانات.
٢. نربط الرابط العام بالكشف لمستخدم غير مخول، فتكون الفئة الإفشاء غير المصرح به.
٣. نربط الملفات المتكررة بتأخر الخدمة الشرعية، فتكون الفئة رفض الخدمة.

السيناريو

مثال محلول:

المعطيات: تعرض ورقة العمل A2 خمسة سيناريوهات: تعديل رقم طلب، وإنكار رفع، ورابط عام، وملفات كبيرة، وخدمة فحص واسعة الصلاحية.

الخطوات:

النتائج: صُنفت الحالات الخمس في 5 فئات مختلفة من STRIDE. ويُختار الضابط وفق الخاصية المتأثرة، لا وفق تشابه أسماء السيناريوهات.



الاحتمالية تقدير لفرصة تحقق حدث ضار ضمن ظروف محددة، وليست ادعاء دقة رقمية مجردة.

يعتمد التقدير على السياق والافتراضات والضوابط الموجودة. في سجل المخاطر، أعطي خطر R-04 احتمالاً مقداره 4، لأن مسار التخزين غير المحمي يمكن أن يتيح الوصول إلى مستندات العملاء إذا لم يفرض تفويضاً دقيقاً.



الأثر تقدير لعواقب تحقق التهديد على أصل أو خدمة محددة.

قد يتعلق بالسرية أو تكامل البيانات أو التوافر أو الالتزامات التشغيلية. في الجدول الحسابي، أعطي خطر R-04 أثراً مقداره 5، لأن الأصل المتأثر هو مخزن مستندات العملاء، وهو يحتوي مستندات تحتاج حماية سرية وتفويضاً دقيقاً للوصول.



- ◀ مصفوفة المخاطر أداة لتنظيم اجتماع الاحتمال والأثر لتوجيه الأولوية، ولا تغني عن التوثيق والحكم المهني.
- ◀ **الوظيفة:** ترتيب المعالجة ومنع إهمال المخاطر الأكثر أهمية.
- ◀ **المسؤوليات:** تعريف المقياس، توثيق الافتراضات، تحديد مالك الخطر، ربط الدرجة بالأصل، مراجعة التقدير.
- ◀ **القواعد:** Risk = Likelihood × Impact، ويخصص الإطار لسياق الجهة.
- ◀ **الأدوات:** مصفوفة تعليمية 5×5، سجل مخاطر، جدول أولويات.
- ◀ **المخرج:** مستوى خطر أو أولوية معالجة مبررة.
- ◀ **مثال:** درجة R-04 هي $20 = 5 \times 4$ ، وهي أعلى درجة في جدول خدمة رفع المستندات.



مصفوفة المخاطر (Risk Matrix) (الشكل)



مثال محلول على النموذج، بناء جدول درجات المخاطر

الجدول: تقدير مخاطر خدمة رفع المستندات

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 · السجل التجاري: 1010000000
هاتف: 0500000000

تقدير مخاطر خدمة رفع المستندات

تاريخ التقييم: 18-03-2026، المقياس من 1 إلى 5، ودرجة الخطر تساوي الاحتمالية مضروبة في الأثر.

معرف الخطر	الأصل المتأثر	الاحتمالية	الأثر	درجة الخطر

يعد المستوى من 1 إلى 4 منخفضاً، ومن 5 إلى 9 متوسطاً، ومن 10 إلى 14 مرتفعاً، ومن 15 إلى 25 حرجاً. التقديرات نوعية تعليمية وليست إحصاءات اختراق.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

المعطيات: تستخدم الشركة مقياساً تعليمياً من 1 إلى 5
للاحتمالية والأثر.

يُحسب مستوى الخطر بحاصل ضرب القيمتين.

تشمل البيانات ستة مخاطر في خدمة رفع المستندات، من R-01
إلى R-06. المطلوب تعبئة الجدول، ثم تحديد أعلى درجة خطر
ومتوسط درجات المخاطر لاتخاذ قرار أولويات المعالجة.

الخطوة 1 من 4: احتساب المخاطر R-01 و R-02

الجدول: تقدير مخاطر خدمة رفع المستندات

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 · السجل التجاري: 1010000000
هاتف: 0500000000

تقدير مخاطر خدمة رفع المستندات

تاريخ التقييم: 18-03-2026، المقياس من 1 إلى 5، ودرجة الخطر تساوي الاحتمالية مضروبة في الأثر.

معرف الخطر	الأصل المتأثر	الاحتمالية	الأثر	درجة الخطر
R-01	رموز جلسات العملاء	3	4	12
R-02	بيانات الطلبات والملفات الوصفية	3	4	12

يعد المستوى من 1 إلى 4 منخفضاً، ومن 5 إلى 9 متوسطاً، ومن 10 إلى 14 مرتفعاً، ومن 15 إلى 25 حرجاً. التقديرات نوعية تعليمية وليست إحصاءات اختراق.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- ◀ تدون قيمة R-01 لرموز جلسات العملاء.
- ◀ الاحتمالية 3 والأثر 4، لذلك تكون الدرجة $3 \times 4 = 12$.
- ◀ ثم تدون R-02 لبيانات الطلبات والملفات الوصفية بالقيم نفسها، فتكون الدرجة 12. الناتج الجزئي يبين أن الخطرين يحتاجان أولوية معالجة منظمة، مع ربط كل درجة بسببها وضابطها.

الخطوة 2 من 4: احتساب المخاطر R-03 و R-04

الجدول: تقدير مخاطر خدمة رفع المستندات

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

تقدير مخاطر خدمة رفع المستندات

تاريخ التقييم: 18-03-2026، المقياس من 1 إلى 5، ودرجة الخطر تساوي الاحتمالية مضروبة في الأثر.

معرف الخطر	الأصل المتأثر	الاحتمالية	الأثر	درجة الخطر
R-01	رموز جلسات العملاء	3	4	12
R-02	بيانات الطلبات والملفات الوصفية	3	4	12
R-03	سجلات تدقيق الرفع والمراجعة	2	3	6
R-04	مخزن مستندات العملاء	4	5	20

يعد المستوى من 1 إلى 4 منخفضاً، ومن 5 إلى 9 متوسطاً، ومن 10 إلى 14 مرتفعاً، ومن 15 إلى 25 حرجاً. التقديرات نوعية تعليمية وليست إحصاءات اختراق.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- تدون R-03 لسجلات تدقيق الرفع والمراجعة.
- الاحتمالية 2 والأثر 3، فتكون الدرجة $2 \times 3 = 6$.
- تعني الدرجة الأقل أن التقدير في هذا الجدول لا يساوي غياب الحاجة إلى الضابط، بل يساند ترتيب الأولوية.
- ثم تدون R-04 لمخزن مستندات العملاء، واحتماله 4 وأثره 5، فتكون الدرجة $4 \times 5 = 20$.
- النتائج الجزئية يحدد R-04 بوصفه أعلى خطر في الصفوف المكتملة، لأن احتمال الوصول غير المصرح به وأثره على المستندات مرتفعان.



الخطوة 2 من 4: احتساب المخاطر R-03 و R-04 (تابع)

◀ مثال محلول:

◀ **المعطيات:** في جدول A3، الاحتمالية والأثر للخطر R-03 هما 2 و3، وللخطر R-04 هما 4 و5.

◀ الخطوات:

1. نطبق العلاقة $\text{Risk} = \text{Likelihood} \times \text{Impact}$ على R-03، فنحصل على $6 = 3 \times 2$.

2. نطبق العلاقة نفسها على R-04، فنحصل على $20 = 5 \times 4$.

3. نقارن الدرجتين: $14 = 6 - 20$.

◀ **النتائج:** تتجاوز درجة R-04 درجة R-03 بمقدار 14 نقطة.

◀ لذلك يسجل R-04 بأولوية معالجة أعلى مع توثيق سبب الدرجة والضابط المختار.

الخطوة 3 من 4: احتساب المخاطر R-05 و R-06

الجدول: تقدير مخاطر خدمة رفع المستندات

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 · السجل التجاري: 1010000000
هاتف: 0500000000

تقدير مخاطر خدمة رفع المستندات

تاريخ التقييم: 18-03-2026، المقياس من 1 إلى 5، ودرجة الخطر تساوي الاحتمالية مضروبة في الأثر.

معرف الخطر	الأصل المتأثر	الاحتمالية	الأثر	درجة الخطر
R-01	رموز جلسات العملاء	3	4	12
R-02	بيانات الطلبات والملفات الوصفية	3	4	12
R-03	سجلات تدقيق الرفع والمراجعة	2	3	6
R-04	مخزن مستندات العملاء	4	5	20
R-05	واجهة رفع الملفات وخدمة الفحص	4	3	12
R-06	خدمة فحص الملفات في البيئة المعزولة	3	5	15

يعد المستوى من 1 إلى 4 منخفضاً، ومن 5 إلى 9 متوسطاً، ومن 10 إلى 14 مرتفعاً، ومن 15 إلى 25 حرجاً. التقديرات نوعية تعليمية وليست إحصاءات اختراق.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- ◀ تدون R-05 لواجهة رفع الملفات وخدمة الفحص.
- ◀ الاحتمالية 4 والأثر 3، فتكون الدرجة $4 \times 3 = 12$.
- ◀ ترتفع احتمالية R-05 لأن الملفات الكبيرة والمتكررة قد تؤخر المعالجة، بينما أثره المقدر أقل من أثر كشف المستندات أو صلاحيات الخدمة.
- ◀ ثم تدون R-06 لخدمة الفحص في البيئة المعزولة.
- ◀ الاحتمالية 3 والأثر 5، فتكون الدرجة $3 \times 5 = 15$.
- ◀ الناتج الجزئي يؤكد أن R-06 يحتاج معالجة ذات أولوية مرتفعة بسبب أثره الكبير على صلاحيات الخدمة.



الخطوة 3 من 4: احتساب المخاطر R-05 و R-06 (تابع)

◀ مثال محلول:

◀ **المعطيات:** يسجل الجدول A3 للخطر R-05 احتمالاً 4 وأثراً 3، وللخطر R-06 احتمالاً 3 وأثراً 5.

◀ الخطوات:

1. نحسب $R-05: 4 \times 3 = 12$.

2. نحسب $R-06: 3 \times 5 = 15$.

3. نقارن النتيجة: $15 - 12 = 3$.

◀ **النتائج:** تزيد درجة R-06 على R-05 بثلاث نقاط.

◀ تعطي المنشأة أولوية أعلى لعزل خدمة الفحص وتشغيلها بأقل الامتيازات، مع استمرار ضوابط الحجم والمعدل ل R-05.

الخطوة 4 من 4: قراءة الناتج والأولوية



الجدول: تقدير مخاطر خدمة رفع المستندات

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 · السجل التجاري: 1010000000
هاتف: 0500000000

تقدير مخاطر خدمة رفع المستندات

تاريخ التقييم: 18-03-2026، المقياس من 1 إلى 5، ودرجة الخطر تساوي الاحتمالية مضروبة في الأثر.

معرف الخطر	الأصل المتأثر	الاحتمالية	الأثر	درجة الخطر
R-01	رموز جلسات العملاء	3	4	12
R-02	بيانات الطلبات والملفات الوصفية	3	4	12
R-03	سجلات تدقيق الرفع والمراجعة	2	3	6
R-04	مخزن مستندات العملاء	4	5	20
R-05	واجهة رفع الملفات وخدمة الفحص	4	3	12
R-06	خدمة فحص الملفات في البيئة المعزولة	3	5	15
متوسط درجة الخطر				13
أعلى درجة خطر				20

يعد المستوى من 1 إلى 4 منخفضاً، ومن 5 إلى 9 متوسطاً، ومن 10 إلى 14 مرتفعاً، ومن 15 إلى 25 حرجاً. التقديرات نوعية تعليمية وليست إحصاءات اختراق.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- يُحسب متوسط درجات المخاطر في الجدول بمقدار 12.83، بينما تبلغ أعلى درجة 20.00 للخطر R-04 الخاص بمخزن مستندات العملاء.
- لا تكفي الدرجة وحدها لاتخاذ القرار، بل تقرأ مع وصف الأصل والتهديد والثغرة.
- الناتج النهائي يدعم ترتيب المعالجة، ثم توثيق الضابط والمالك وتاريخ المراجعة في سجل المخاطر.



سجل المخاطر وخيارات المعالجة



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

سجل مخاطر الأمن السيبراني

المنشأة: شركة الحلول التقنية والخدمات الرقمية، النطاق: خدمة رفع مستندات العملاء، تاريخ الإصدار: 19-03-2026.

المعرف	الأصل	التهديد والتفرة	خيار المعالجة	الضابط أو الإجراء	مالك الخطر	تاريخ المراجعة
R-01	رموز جلسات العملاء	استخدام رمز جلسة مسروق عند غياب تحقق إضافي من الجلسة.	تخفيف	ضبط خصائص ملفات الارتباط الآمنة، انتهاء الجلسة، كشف السلوك غير المعتاد، ومراجعة المصادقة متعددة العوامل.	مسؤول المنصة الرقمية	2026-06-19
R-02	بيانات الطلبات والملفات الوصفية	تعديل البيانات أثناء الإرسال أو عبر مدخلات غير متحققة في البوابة.	تخفيف	فرض HTTPS، تحقق خادمي من المدخلات، حفظ بصمة للملف، واختبارات أمنية قبل النشر.	مسؤول تطوير المنصة	2026-06-19
R-03	سجلات تدقيق الرفع والمراجعة	إنكار عملية رفع أو مراجعة بسبب سجلات ناقصة أو قابلية للتغيير دون مراجعة.	تخفيف	تسجيل وقت العملية ومعرف الطلب والنتيجة، تنفيذ تعديل السجلات، ومراجعة دورية للسجلات.	مسؤول التشغيل السحابي	2026-07-19
R-04	مخزن مستندات العملاء	قراءة مستندات عميل من رابط أو مسار تخزين غير محمي بتفويض دقيق.	تخفيف فوري مع إصلاح جذري مجدول	إيقاف الروابط العامة، فرض تفويض خادمي لكل تنزيل، تشفير التخزين، وتنفيذ إعادة تصميم لصلاحيات الوصول.	مسؤول الأمن السيبراني	2026-04-02
R-05	واجهة رفع الملفات وخدمة الفحص	إغراق نقطة الرفع بملفات كبيرة ومتكررة يؤدي إلى تأخر الخدمة.	تخفيف	تحديد الحجم والمعدل، استخدام طابور معالجة، تنبيه عند تجاوز السعة، ومراجعة موارد البيئة المعزولة.	مسؤول التشغيل السحابي	2026-06-19
R-06	خدمة فحص الملفات في البيئة المعزولة	استغلال ملف خبيث لخدمة تعمل بصلاحيات أوسع من اللازم.	تجنب جزئي وتخفيف	منع التنفيذ من مسار الرفع، عزل الفحص، تشغيل الخدمة بأقل الامتيازات، وتحديث المكونات قبل إعادة فتح المسار المتأثر.	مسؤول تطوير المنصة	2026-05-19

تتوافق المعرفات مع جدول تقدير المخاطر، لا يعد النقل أو القبول بديلاً عن الضوابط المطلوبة لحماية البيانات الشخصية.

مستند تعليمي إقتراضي، الأسماء والأرقام غير حقيقية

أقرأ سجل المخاطر بعد حساب الدرجات.

يربط السجل كل معرف خطر بأصل، ووصف تهديد وثغرة، وخيار معالجة، وضابط، ومالك خطر، وتاريخ مراجعة.

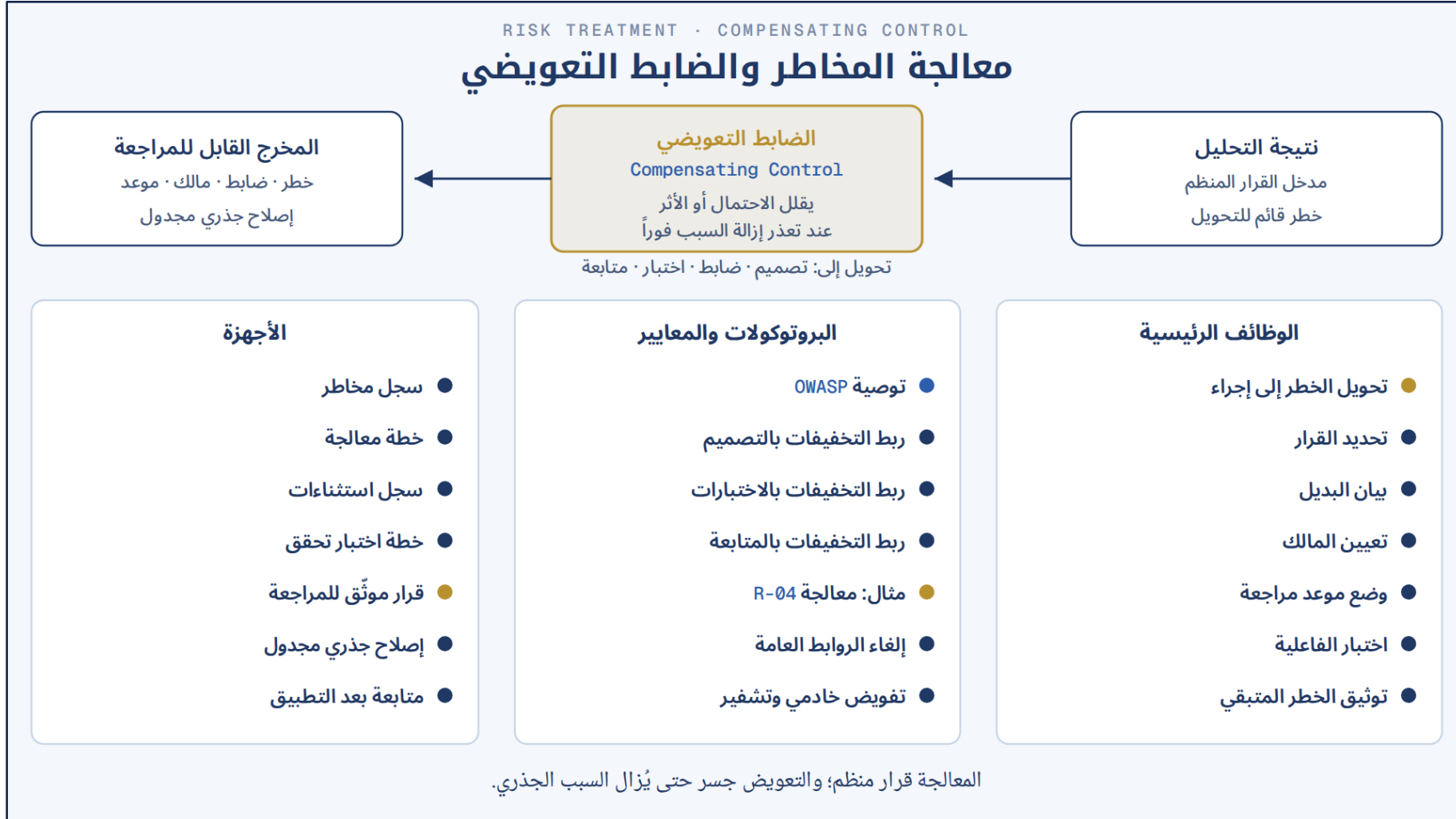
لاحظ أن R-04 يعالج بتخفيف فوري مع إصلاح جذري مجدول، لأن مخزن المستندات يحتاج إيقاف الروابط العامة وفرض تفويض خادمي لكل تنزيل.



- ◀ معالجة المخاطر قرار منظم يحول نتيجة التحليل إلى تغيير تصميم أو ضابط أو اختبار أو متابعة.
- ◀ الضابط التعويضي يقلل الاحتمال أو الأثر عند تعذر إزالة السبب الجذري فوراً.
- ◀ **الوظيفة:** تحويل الخطر إلى إجراء قابل للمراجعة.
- ◀ **المسؤوليات:** تحديد القرار، بيان البديل، تعيين المالك، وضع موعد مراجعة، اختبار الفاعلية، توثيق الخطر المتبقي.
- ◀ **القواعد:** توصي OWASP بربط التخفيفات بتغييرات التصميم والاختبارات والمتابعة.
- ◀ **الأدوات:** سجل مخاطر، خطة معالجة، سجل استثناءات، خطة اختبار تحقق.
- ◀ **المخرج:** قرار يتضمن الخطر والضابط والمالك والموعد.
- ◀ **مثال:** يعالج R-04 بإلغاء الروابط العامة والتفويض الخادمي والتشفير وإصلاح جذري مجدول.



معالجة المخاطر والضابط التعويضي (Compensating Control) (الشكل)





تجنب المخاطر وتخفيفها ونقلها وقبولها

خيار المعالجة	متى يستخدم	مثال من الخدمة	شرط الحوكمة
التجنب	إزالة سبب الخطر	منع التنفيذ من مسار الرفع	توثيق أثر القرار
التخفيف	خفض الاحتمال أو الأثر	تحقق خادمي وتشفير	اختبار فاعلية الضابط
النقل	مشاركة أثر الخطر تعاقدياً	خدمة خارجية ضمن اتفاقية	متابعة الخطر المتبقي
القبول الموثق	خطر متبق محدود ومبرر	استثناء مؤقت مضبوط	موافقة ومالك وتاريخ مراجعة



قبول المخاطر الاستثنائي



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم المبرسي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

النموذج: نموذج قبول خطر استثنائي وضوابط تعويضية

نموذج قبول خطر استثنائي وضوابط تعويضية

رقم الطلب:	RA-2026-007
تاريخ الطلب:	2026-03-20
مرجع الخطر:	R-04 في سجل مخاطر خدمة رفع المستندات
وصف الاستثناء:	توجد صلاحية مؤقتة أوسع من المطلوب لفريق المراجعة للوصول إلى مجلد مستندات العملاء أثناء انتقال إعدادات التخزين إلى نموذج تفويض خادمي دقيق.
سبب عدم إيقاف الخدمة فوراً:	إيقاف الخدمة يمنع العملاء من رفع مستندات لازمة لمعالجة الطلبات القائمة، بينما الإصلاح يتطلب اختيار تكامل واجهة الرفع والتخزين.
قرار المعالجة:	قبول مؤقت للمخاطر المتبقية مع تخفيف فوري وإصلاح جذري إلزامي قبل انتهاء الاستثناء.
الضابط التعويضي الأول:	إلغاء أي رابط عام، وقصر الوصول على حسابات الموظفين المخولين عبر مصادقة متعددة العوامل.
الضابط التعويضي الثاني:	مراجعة يومية لسجل تنزيل المستندات والتنبيه الفوري لمسؤول الأمن السيبراني عند تنزيل غير معتاد.
الضابط التعويضي الثالث:	موافقة ثنائية موثقة من مسؤول المنصة ومسؤول الأمن السيبراني قبل منح أو تعديل صلاحية الوصول.
الإصلاح الجذري المطلوب:	تنفيذ تفويض خادمي لكل عملية تنزيل وفق هوية العميل أو الموظف ودوره، ثم إجراء اختبار صلاحيات واختبار اختراق محدود للنطاق.
مالك الخطر:	مسؤول المنصة الرقمية
صاحب اعتماد الاستثناء:	مدير الأمن السيبراني
تاريخ انتهاء الاستثناء:	2026-04-02
تاريخ المراجعة المرحلية:	2026-03-27
حالة الطلب:	مقبول مؤقتاً بشرط تنفيذ الضوابط التعويضية وتوثيق نتيجة الإصلاح الجذري.

لا يجوز تمديد الاستثناء دون إعادة التقييم والأثر وتوثيق قرار جديد من صاحب الصلاحية.

مقدم الطلب	المسؤول	الاعتماد
مستند تخطيطي إلكتروني: الأسماء والأرقام غير حقيقية		

- يوثق النموذج الطلب RA-2026-007 المرتبط بالخطر R-04. القبول مؤقت، ولا يعني تجاهل الخطر.
- يحدد النموذج إلغاء الروابط العامة، والمصادقة متعددة العوامل للحسابات المخولة، ومراجعة يومية لسجل التنزيل، وموافقة ثنائية قبل تعديل الصلاحيات.
- وينتهي الاستثناء في 2026-04-02 بعد تنفيذ الإصلاح الجذري واختبار الصلاحيات.

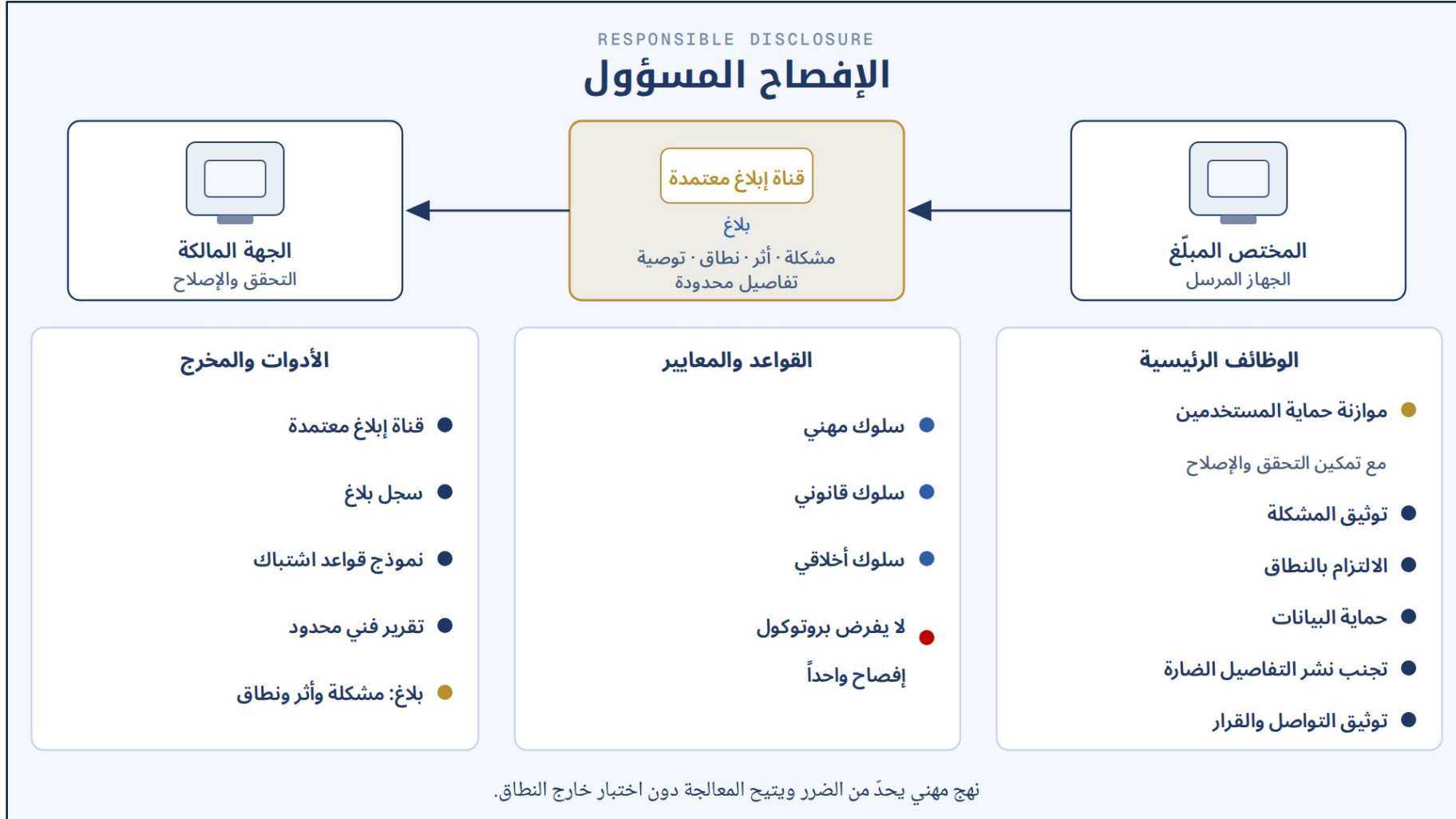


(Responsible Disclosure) الإفصاح المسؤول

- ◀ الإفصاح المسؤول نهج مهني للإبلاغ الجهة المسؤولة عن مشكلة أمنية بما يحد من الضرر ويتيح المعالجة.
- ◀ **الوظيفة:** موازنة حماية المستخدمين مع تمكين الجهة المالكة من التحقق والإصلاح.
- ◀ **المسؤوليات:** توثيق المشكلة، الالتزام بالنطاق، حماية البيانات، تجنب نشر التفاصيل الضارة، توثيق التواصل والقرار.
- ◀ **القواعد:** يرتبط بالسلوك المهني والقانوني والأخلاقي، ولا يفرض بروتوكول إفصاح واحداً.
- ◀ **الأدوات:** قناة إبلاغ معتمدة، سجل بلاغ، نموذج قواعد اشتباك، تقرير فني محدود التفاصيل.
- ◀ **المخرج:** بلاغ يصف المشكلة والأثر والنطاق والتوصية.
- ◀ **مثال:** يبلغ المختص مالك خدمة رفع المستندات عن صلاحية مفرطة في بيئة مصرح بها دون اختبار خارج النطاق.



(الشكل) (Responsible Disclosure) الإفصاح المسؤول





توجد صلاحية مؤقتة أوسع من المطلوب لفريق المراجعة للوصول إلى مجلد مستندات العملاء.

أوقف الروابط العامة فوراً، وقصر الوصول على حسابات الموظفين المخولين، وراجع سجل التنزيل يوميا. لا يمثل ذلك بديلاً دائماً عن الإصلاح. يجب تنفيذ تفويض خادمي لكل تنزيل وفق هوية العميل أو الموظف ودوره قبل انتهاء الاستثناء.



نشاط تقويمي، قرار معالجة الخطر R-04



- ◀ الزمن: 30 دقيقة.
- ◀ الخطر R-04 يرتبط بمخزن مستندات العملاء، واحتماله 4 وأثره 5 ودرجته 20. اقترح قرار معالجة من ثلاثة أجزاء: إجراء فوري، وضابط تعويضي خلال فترة الإصلاح، وإصلاح جذري طويل الأجل.
- ◀ حدد مالك الخطر وتاريخ المراجعة من سجل المخاطر، ثم قارنها بمالك الاستثناء وتاريخ مراجعته المرحلية في الطلب RA-2026-007، وبرر الفرق في ثلاثة أسطر.



إجابة النشاط، قرار معالجة الخطر R-04



- ◀ الإجراء الفوري هو إيقاف الروابط العامة لمخزن المستندات، لأنه يمنع مسار الوصول غير المحمي مباشرة.
- ◀ الضابط التعويضي هو قصر الوصول على الحسابات المخولة مع مصادقة متعددة العوامل ومراجعة يومية لسجل التنزيل، لأنه يقلل التعرض خلال فترة الإصلاح ولا يزيل سبب الخطر.
- ◀ الإصلاح الجذري هو تنفيذ تفويض خادمي لكل عملية تنزيل واختبار الصلاحيات، لأنه يفرض القرار وفق هوية العميل أو الموظف ودوره.
- ◀ مالك الخطر في سجل المخاطر هو مسؤول الأمن السيبراني، وتاريخ المراجعة هو 2026-04-02. أما طلب الاستثناء فيعين مسؤول المنصة الرقمية مالكا للخطر ويحدد مراجعة مرحلية في 2026-03-27 لمتابعة الضوابط التعويضية.



إجابة النشاط، قرار معالجة الخطر R-04 (تابع)

المطلوب

١. نحسب الفترة إلى المراجعة: من 2026-03-20 إلى 2026-03-27 تساوي 7 أيام.
٢. نحسب الفترة الكلية للاستثناء: من 2026-03-20 إلى 2026-04-02 تساوي 13 يوماً.
٣. نربط الأيام الثلاثة عشر بإيقاف الروابط العامة والمراجعة اليومية وتنفيذ التفويض الخادمي قبل الانتهاء.

السيناريو

مثال محلول:

المعطيات: طلب الاستثناء RA-2026-007 يتعلق بالخطر R-04. تاريخ الطلب 2026-03-20، وتاريخ المراجعة 2026-03-27، وتاريخ انتهاء الاستثناء 2026-04-02.

الخطوات:

النتائج: قبول R-04 مؤقت لمدة 13 يوماً مع مراجعة بعد 7 أيام.
لا يستمر القبول بعد 2026-04-02 دون توثيق نتيجة الإصلاح الجذري.



✓ **يطبق** الهدف الثاني نموذج STRIDE على العناصر والتدفقات وحدود الثقة.

✓ **يميز** الهدف الأول بين التهديد والثغرة والأثر والمخاطر، ويربطها بالأصل والسياق.

✓ **يدعم** الهدف الرابع المقارنة بين التجنب والتخفيف والنقل والقبول الموثق.

✓ **يحقق** الهدف الثالث بتقدير الاحتمال والأثر وحساب درجة الخطر وترتيب المعالجة.

✓ **يحقق** الهدف الخامس توثيق القرار والضابط التعويضي والإفصاح المسؤول بصورة أخلاقية ومهنية.



- ▶ Shostack, Adam. (2014). Threat Modeling: Designing for Security. Wiley. يدعم STRIDE. وشجرة الهجوم ومعالجة التهديدات.
- ▶ National Institute of Standards and Technology. Guide for Conducting Risk Assessments. NIST SP 800-30 Rev. 1. يدعم مفاهيم تقييم المخاطر والأصل والأثر.
- ▶ OWASP Foundation. OWASP Threat Modeling Project. يدعم اختيار منهج النمذجة وترتيب المخاطر والتخفيفات.
- ▶ OWASP Foundation. Threat Modeling Process (Historical). يدعم خطوات النطاق والأصول وحدود الثقة.
- ▶ OWASP Foundation. OWASP Risk Rating Methodology. يدعم العلاقة بين الاحتمال والأثر وتخصيص التقدير للسياق.
- ▶ Anderson, Ross. (2020). Security Engineering: A Guide to Building Dependable Distributed Systems (3rd ed.). Wiley. يدعم الحدود والحوافز والتطوير الآمن.
- ▶ Bergh Johnsson, Dan, Deogun, Daniel, and Sawano, Daniel. (2019). Secure by Design. Manning Publications. يدعم إدماج الأمن في التصميم.
- ▶ Stallings, William. (2016). Cryptography and Network Security: Principles and Practice (7th Global ed.). Pearson Education. يدعم مفاهيم السرية وتكامل البيانات والتوافر.



المرجع	الجزء المدعوم في الفصل
Shostack	STRIDE وشجرة الهجوم والمعالجة
NIST SP 800-30 Rev. 1	تقييم المخاطر والأثر
OWASP Risk Rating Methodology	الاحتمال والأثر والمصفوفة
Anderson	الحدود والحواجز



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شكراً لكم

معهد البحوث والخدمات الاستشارية – جامعة جازان